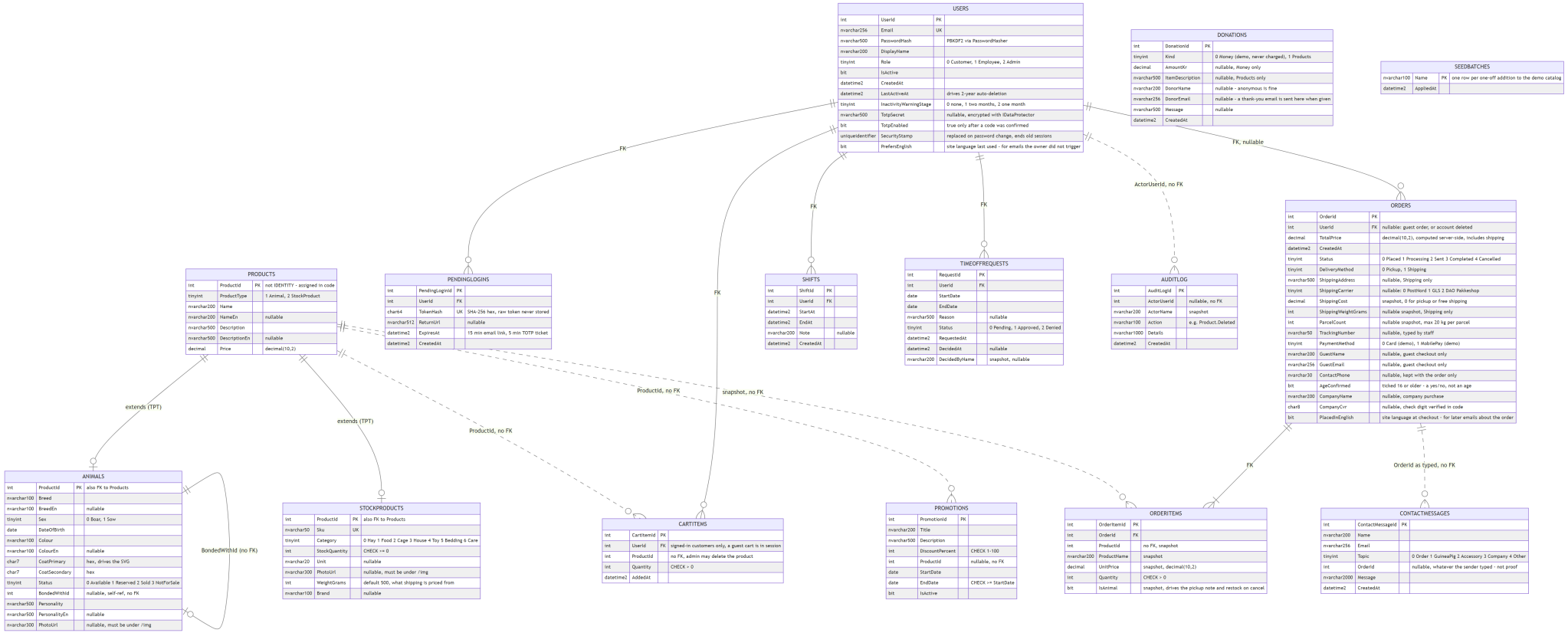
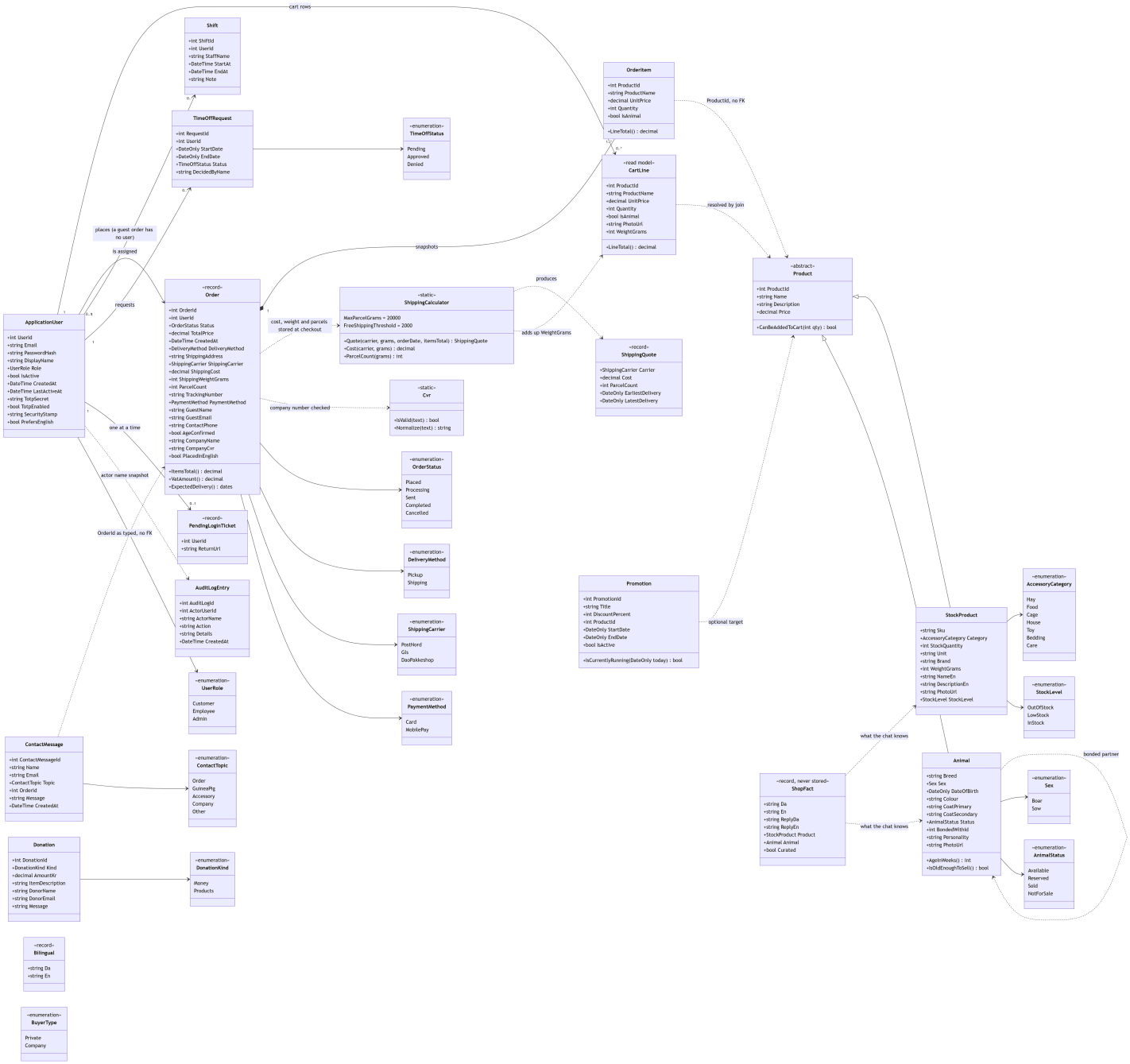
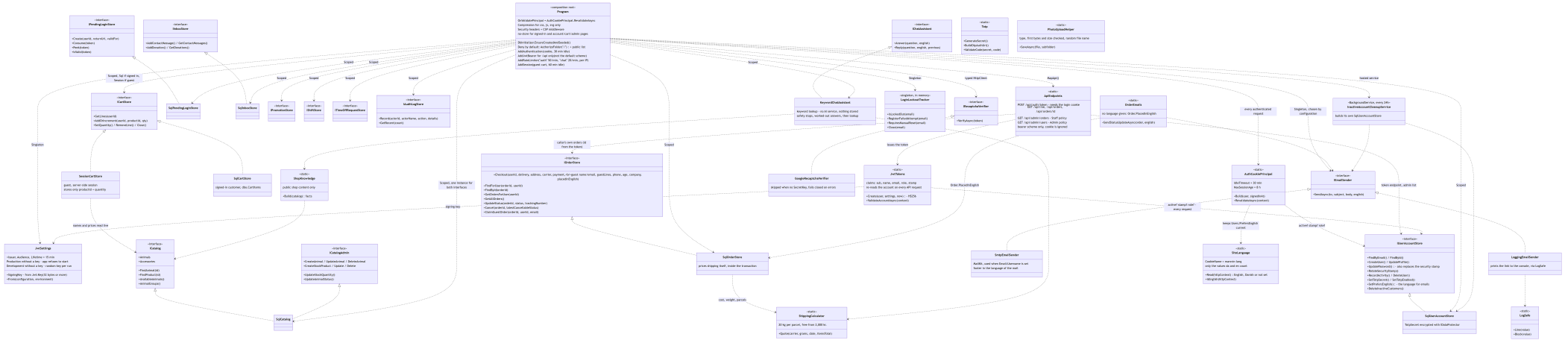
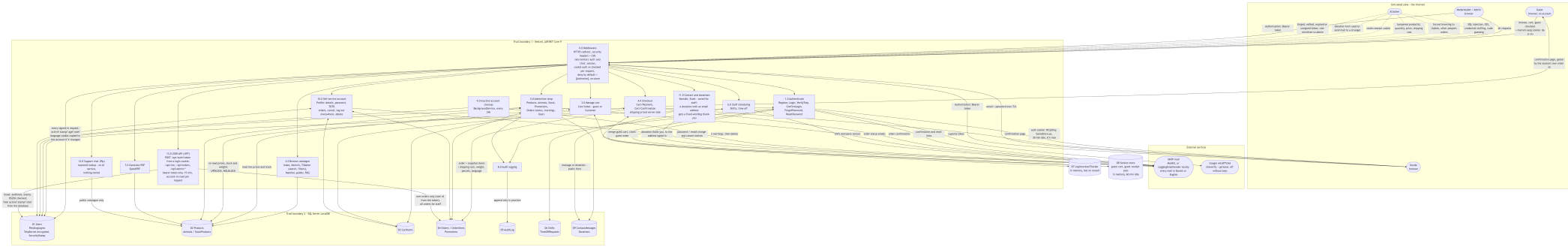
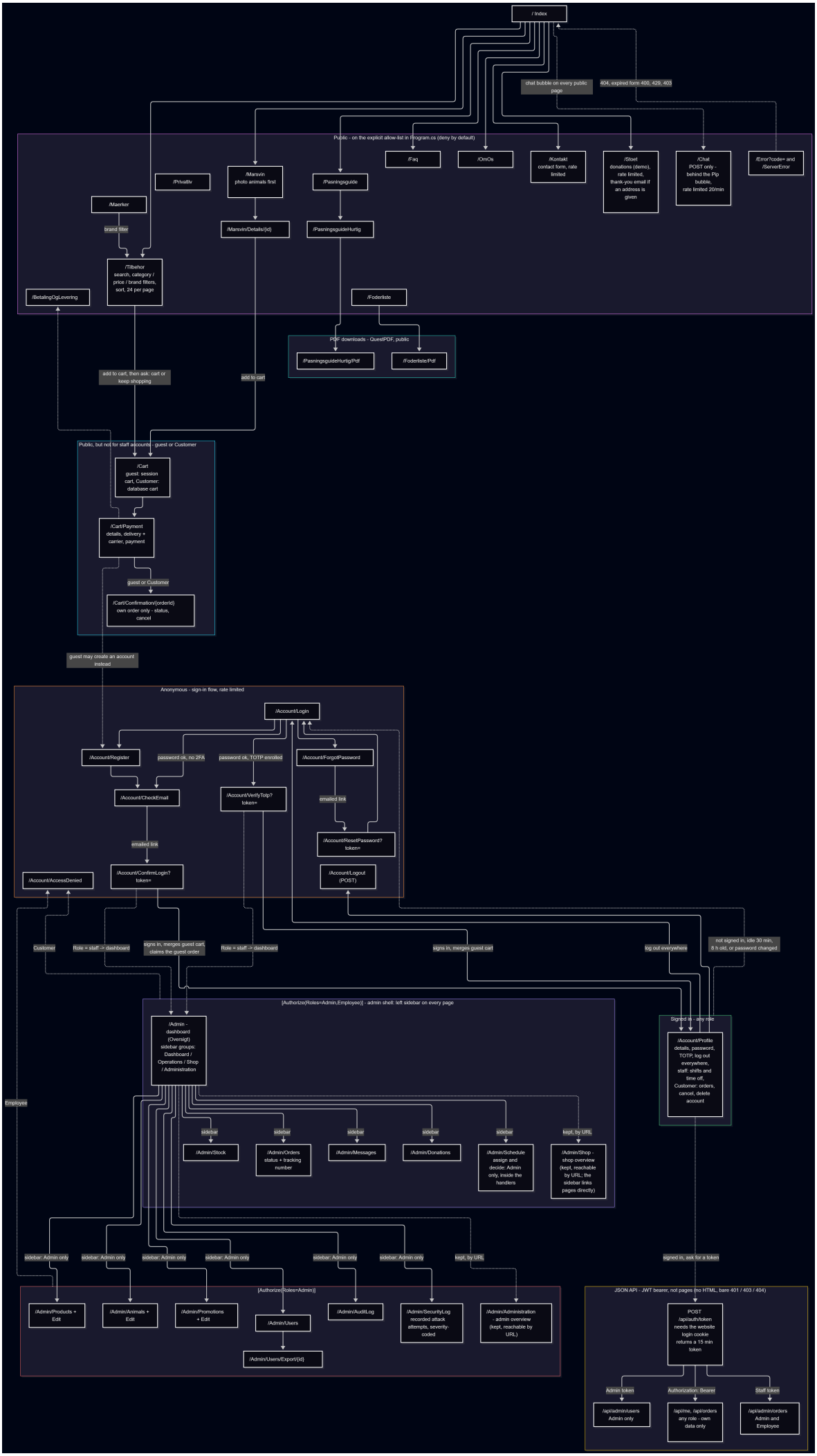
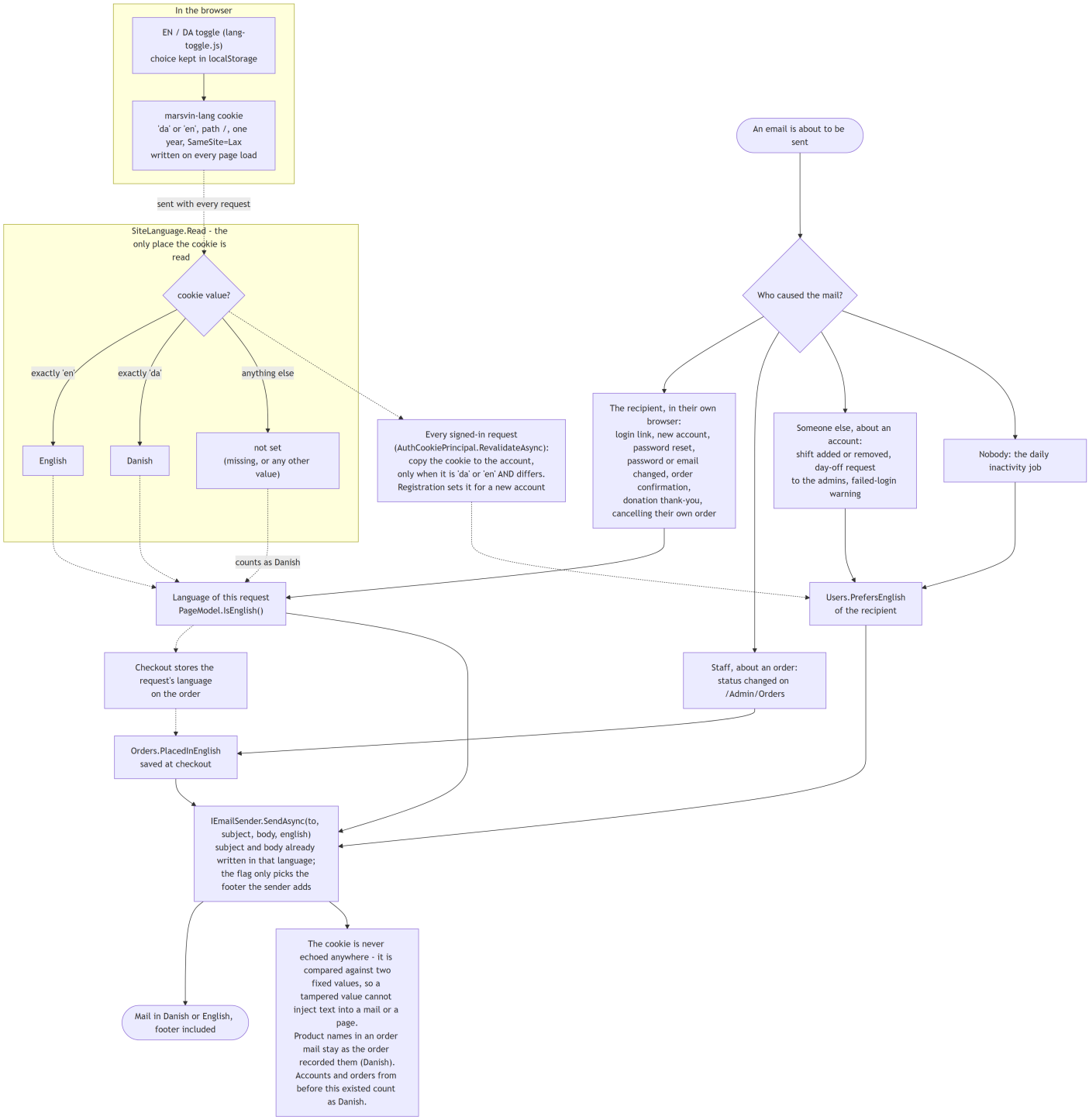

USERS
int | UserId | PK
nvarchar256 | Email | UK
nvarchar500 | PasswordHash | PBKDF2 via PasswordHasher
nvarchar200 | DisplayName
tinyint | Role | 0 Customer, 1 Employee, 2 Admin
bit | IsActive
datetime2 | CreatedAt
datetime2 | LastActiveAt | drives 2-year auto-deletion
tinyint | InactivityWarningStage | 0 none, 1 two months, 2 one month
nvarchar500 | TotpSecret | nullable, encrypted with IDataProtector
bit | TotpEnabled | true only after a code was confirmed
uniqueidentifier | SecurityStamp | replaced on password change, ends old sessions
bit | PrefersEnglish | site language last used - for emails the owner did not trigger
DONATIONS
int | DonationId | PK
tinyint | Kind | 0 Money (demo, never charged), 1 Products
decimal | AmountKr | nullable, Money only
nvarchar500 | ItemDescription | nullable, Products only
nvarchar200 | DonorName | nullable - anonymous is fine
nvarchar256 | DonorEmail | nullable - a thank-you email is sent here when given
nvarchar500 | Message | nullable
datetime2 | CreatedAt
SEEDBATCHES
nvarchar100 | Name | PK | one row per one-off addition to the demo catalog
datetime2 | AppliedAt
PRODUCTS
int | ProductId | PK | not IDENTITY - assigned in code
tinyint | ProductType | | 1 Animal, 2 StockProduct
nvarchar200 | Name
nvarchar200 | NameEn | | nullable
nvarchar500 | Description
nvarchar500 | DescriptionEn | | nullable
decimal | Price | | decimal(10,2)
PENDINGLOGINS
int | PendingLoginId | PK
int | UserId | FK
char64 | TokenHash | UK | SHA-256 hex, raw token never stored
nvarchar512 | ReturnUrl | | nullable
datetime2 | ExpiresAt | | 15 min email link, 5 min TOTP ticket
datetime2 | CreatedAt
SHIFTS
int | ShiftId | PK
int | UserId | FK
datetime2 | StartAt
datetime2 | EndAt | | nullable
nvarchar200 | Note | | nullable
datetime2 | CreatedAt
TIMEOFFREQUESTS
int | RequestId | PK
int | UserId | FK
date | StartDate
date | EndDate
nvarchar500 | Reason | | nullable
tinyint | Status | | 0 Pending, 1 Approved, 2 Denied
datetime2 | RequestedAt
datetime2 | DecidedAt | | nullable
nvarchar200 | DecidedByName | | snapshot, nullable
AUDITLOG
int | AuditLogId | PK
int | ActorUserId | | nullable, no FK
nvarchar200 | ActorName | | snapshot
nvarchar100 | Action | | e.g. Product.Deleted
nvarchar1000 | Details
datetime2 | CreatedAt
ORDERS
int | OrderId | PK
int | UserId | FK | nullable: guest order, or account deleted
decimal | TotalPrice | | decimal(10,2), computed server-side, includes shipping
datetime2 | CreatedAt
tinyint | Status | | 0 Placed 1 Processing 2 Sent 3 Completed 4 Cancelled
tinyint | DeliveryMethod | | 0 Pickup, 1 Shipping
nvarchar500 | ShippingAddress | | nullable, Shipping only
tinyint | ShippingCarrier | | nullable: 0 PostNord 1 GLS 2 DAO Pakkeshop
decimal | ShippingCost | | snapshot, 0 for pickup or free shipping
int | ShippingWeightGrams | | nullable snapshot, Shipping only
int | ParcelCount | | nullable snapshot, max 20 kg per parcel
nvarchar50 | TrackingNumber | | nullable, typed by staff
tinyint | PaymentMethod | | 0 Card (demo), 1 MobilePay (demo)
nvarchar200 | GuestName | | nullable, guest checkout only
nvarchar256 | GuestEmail | | nullable, guest checkout only
nvarchar30 | ContactPhone | | nullable, kept with the order only
bit | AgeConfirmed | | ticked 16 or older - a yes/no, not an age
nvarchar200 | CompanyName | | nullable, company purchase
char8 | CompanyCvr | | nullable, check digit verified in code
bit | PlacedInEnglish | | site language at checkout - for later emails about the order
ANIMALS
int | ProductId | PK | also FK to Products
nvarchar100 | Breed
nvarchar100 | BreedEn | | nullable
tinyint | Sex | | 0 Boar, 1 Sow
date | DateOfBirth | | nullable
nvarchar100 | Colour
nvarchar100 | ColourEn | | nullable
char7 | CoatPrimary | | hex, drives the SVG
char7 | CoatSecondary | | hex
tinyint | Status | | 0 Available 1 Reserved 2 Sold 3 NotForSale
int | BondedWithId | | nullable, self-ref, no FK
nvarchar500 | Personality
nvarchar500 | PersonalityEn | | nullable
nvarchar300 | PhotoUrl | | nullable, must be under /img
STOCKPRODUCTS
int | ProductId | PK | also FK to Products
nvarchar50 | Sku | UK
tinyint | Category | | 0 Hay 1 Food 2 Cage 3 House 4 Toy 5 Bedding 6 Care
int | StockQuantity | | CHECK >= 0
nvarchar20 | Unit | | nullable
nvarchar300 | PhotoUrl | | nullable, must be under /img
int | WeightGrams | | default 500, what shipping is priced from
nvarchar100 | Brand | | nullable
CARTITEMS
int | CartItemId | PK
int | UserId | FK | signed-in customers only, a guest cart is in session
int | ProductId | | no FK, admin may delete the product
int | Quantity | | CHECK > 0
datetime2 | AddedAt
PROMOTIONS
int | PromotionId | PK
nvarchar200 | Title
nvarchar500 | Description
int | DiscountPercent | | CHECK 1-100
int | ProductId | | nullable, no FK
date | StartDate
date | EndDate | | CHECK >= StartDate
bit | IsActive
ORDERITEMS
int | OrderItemId | PK
int | OrderId | FK
int | ProductId | | no FK, snapshot
nvarchar200 | ProductName | | snapshot
decimal | UnitPrice | | snapshot, decimal(10,2)
int | Quantity | | CHECK > 0
bit | IsAnimal | | snapshot, drives the pickup note and restock on cancel
CONTACTMESSAGES
int | ContactMessageId | PK
nvarchar200 | Name
nvarchar256 | Email
tinyint | Topic | | 0 Order 1 GuineaPig 2 Accessory 3 Company 4 Other
int | OrderId | | nullable, whatever the sender typed - not proof
nvarchar2000 | Message
datetime2 | CreatedAt
FK
FK
FK
FK
FK, nullable
ActorUserId, no FK
extends (TPT)
extends (TPT)
ProductId, no FK
ProductId, no FK
snapshot, no FK
FK
OrderId as typed, no FK
BondedWithId (no FK)

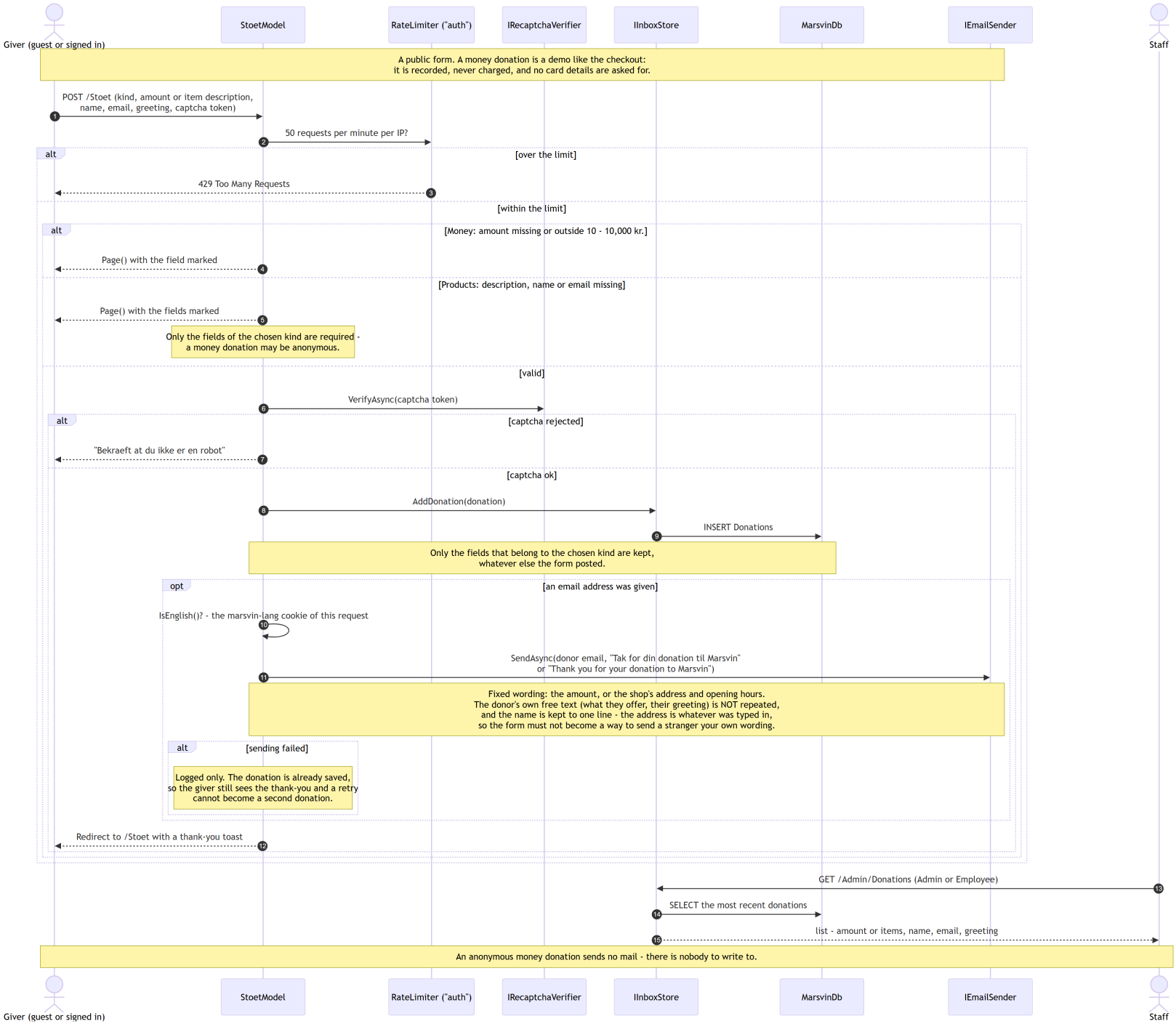

Shift
+int ShiftId
+int UserId
+string StaffName
+DateTime StartAt
+DateTime EndAt
+string Note
TimeOffRequest
+int RequestId
+int UserId
+DateOnly StartDate
+DateOnly EndDate
+TimeOffStatus Status
+string DecidedByName
«enumeration»
TimeOffStatus
Pending
Approved
Denied
cart rows
OrderItem
+int ProductId
+string ProductName
+decimal UnitPrice
+int Quantity
+bool IsAnimal
+LineTotal() : decimal
ProductId, no FK
«read model»
CartLine
+int ProductId
+string ProductName
+decimal UnitPrice
+int Quantity
+bool IsAnimal
+string PhotoUrl
+int WeightGrams
+LineTotal() : decimal
resolved by join
«abstract»
Product
+int ProductId
+string Name
+string Description
+decimal Price
+CanBeAddedToCart(int qty) : bool
places (a guest order has no user)
is assigned
snapshots
requests
ApplicationUser
+int UserId
+string Email
+string PasswordHash
+string DisplayName
+UserRole Role
+bool IsActive
+DateTime CreatedAt
+DateTime LastActiveAt
+string TotpSecret
+bool TotpEnabled
+string SecurityStamp
+bool PrefersEnglish
«record»
Order
+int OrderId
+int UserId
+OrderStatus Status
+decimal TotalPrice
+DateTime CreatedAt
+DeliveryMethod DeliveryMethod
+string ShippingAddress
+ShippingCarrier ShippingCarrier
+decimal ShippingCost
+int ShippingWeightGrams
+int ParcelCount
+string TrackingNumber
+PaymentMethod PaymentMethod
+string GuestName
+string GuestEmail
+string ContactPhone
+bool AgeConfirmed
+string CompanyName
+string CompanyCvr
+bool PlacedInEnglish
+ItemsTotal() : decimal
+VatAmount() : decimal
+ExpectedDelivery() : dates
cost, weight and parcels stored at checkout
«static»
ShippingCalculator
MaxParcelGrams = 20000
FreeShippingThreshold = 2000
+Quote(carrier, grams, orderDate, itemsTotal) : ShippingQuote
+Cost(carrier, grams) : decimal
+ParcelCount(grams) : int
produces
adds up WeightGrams
«record»
ShippingQuote
+ShippingCarrier Carrier
+decimal Cost
+int ParcelCount
+DateOnly EarliestDelivery
+DateOnly LatestDelivery
company number checked
«static»
Cvr
+IsValid(text) : bool
+Normalize(text) : string
one at a time
actor name snapshot
«enumeration»
OrderStatus
Placed
Processing
Sent
Completed
Cancelled
«record»
PendingLoginTicket
+int UserId
+string ReturnUrl
OrderId as typed, no FK
«enumeration»
DeliveryMethod
Pickup
Shipping
AuditLogEntry
+int AuditLogId
+int ActorUserId
+string ActorName
+string Action
+string Details
+DateTime CreatedAt
«enumeration»
ShippingCarrier
PostNord
Gls
DaoPakkeshop
«enumeration»
UserRole
Customer
Employee
Admin
«enumeration»
PaymentMethod
Card
MobilePay
Promotion
+int PromotionId
+string Title
+int DiscountPercent
+int ProductId
+DateOnly StartDate
+DateOnly EndDate
+bool IsActive
+IsCurrentlyRunning(DateOnly today) : bool
optional target
StockProduct
+string Sku
+AccessoryCategory Category
+int StockQuantity
+string Unit
+string Brand
+int WeightGrams
+string NameEn
+string DescriptionEn
+string PhotoUrl
+StockLevel StockLevel
«enumeration»
AccessoryCategory
Hay
Food
Cage
House
Toy
Bedding
Care
«enumeration»
StockLevel
OutOfStock
LowStock
InStock
ContactMessage
+int ContactMessageId
+string Name
+string Email
+ContactTopic Topic
+int OrderId
+string Message
+DateTime CreatedAt
«enumeration»
ContactTopic
Order
GuineaPig
Accessory
Company
Other
Donation
+int DonationId
+DonationKind Kind
+decimal AmountDkr
+string ItemDescription
+string DonorName
+string DonorEmail
+string Message
«enumeration»
DonationKind
Money
Products
«record»
Bilingual
+string Da
+string En
«enumeration»
BuyerType
Private
Company
«record, never stored»
ShopFact
+string Da
+string En
+string ReplyDa
+string ReplyEn
+StockProduct Product
+Animal Animal
+bool Curated
what the chat knows
what the chat knows
Animal
+string Breed
+Sex Sex
+DateOnly DateOfBirth
+string Colour
+string CoatPrimary
+string CoatSecondary
+AnimalStatus Status
+int BondedWithId
+string Personality
+string PhotoUrl
+AgeInWeeks() : int
+IsOldEnoughToSell() : bool
bonded partner
«enumeration»
Sex
Boar
Sow
«enumeration»
AnimalStatus
Available
Reserved
Sold
NotForSale

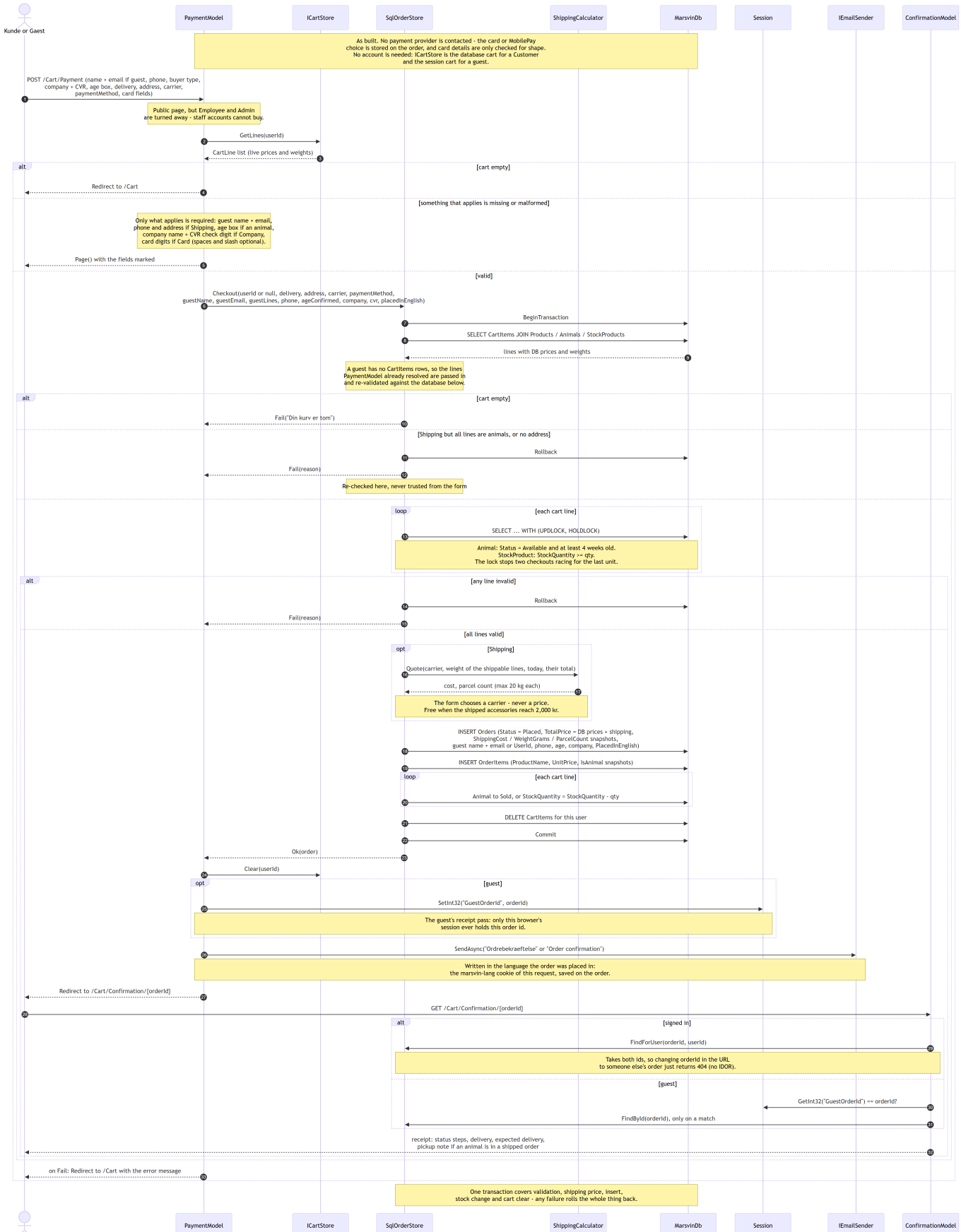

«interface»
IPendingLoginStore
+Create(userId, returnUrl, validFor)
+Consume(token)
+Peek(token)
+Validate(token)
«interface»
IInboxStore
+Add(ContactMessage) / GetContactMessages()
+Add(Emailing) / GetEmailings()
«composition root»
Program
Dir.Validate(Principal) + AuditCookieMiddleware
Compression for .css, .js, .svg only
Security headers + CSP middleware
no-store for signed-in and account/cart/admin pages
DistributedSessionProtectionDataDir(Directory.GetCurrentDirectory() + "/.dp-keys")
Data by default: AuthenticationFailure("") + public list
AddAuthentication(cookie, 30 min idle)
AddJwtBearer for "api" endpoint the default scheme)
AddRateLimiter("auth" 10/min, "chat" 20/min, per IP)
AddEmailingHost cert, 60 sec idle)
«interface»
IChatAssistant
+Answer(question, english)
+Rephrase(question, english, previous)
«static»
Tags
+Generate(flavor)
-BuildSpiceBlend()
-Validate(codeContent, node)
«static»
PhotoUploadHelper
type, first bytes and size checked, random file name
-Save(stream, subfolder)
Scoped, fail if signed in, Session if guest
Scoped
Scoped
Scoped
Scoped
Scoped
Scoped
Scoped
Singleton
typed HttpClient
Reader()
hosted service
«interface»
ICartStore
+Get(browserId)
+Add(browserId,userId, productId, qty)
+Set(quantity) / Remove(line) / Clear()
SqlPendingLoginStore
SqlInboxStore
«interface»
IPromotionStore
«interface»
IDraftStore
«interface»
ITimedOfferLevelStore
«interface»
IAuditLogStore
+Record(actorId, actorName, action, details)
+GetRecent(count)
KeyvaultDataSeeder
keyword lookup - no AI service, nothing stored
safety stops, worked-out answers, then lookup
«singleton, in-memory»
LoginLockoutTracker
+BlockedOutcome()
-RegisterFailure(normalizedEmail)
-ResetOnSuccess(normalizedEmail)
-Clone(email)
«interface»
IManagerAuthVerifier
-VerifyAsync(token)
«static»
SqlEndpoints
POST /api/auth/token - issues the login cookie
body: { "key": "..." }
login token id
GET /api/admin/orders - Staff policy
GET /api/admin/users - Admin policy
bearer scheme only, cookies is ignored
«static»
OrderEmails
no language given: Order.PlacedInEnglish
-SendStatusUpdateAsync(order, english)
every authenticated request
Singleton, chosen by configuration
«BackgroundService, every 24h»
PurgeOldAccountTokensJanitor
batch 01 over SqlUserAccountStore
Singleton
SessionCartStore
guest, server role session
stores only productId + quantity
SqlCartStore
signed-in customer, dbo.CartItems
«static»
ShopKnowledge
public shop content only
-Build(catalog) : facts
Scoped, one instance for both interfaces
«interface»
IOrderStore
+CheckoutAsync(id, delivery, address, carrier, payment, rtp-quest name/email, guestLines, phone, age, company, placedInEnglish)
+FindForUser(orderId, userId)
+ListForUser(userId)
+SetDeliveryPerson(userId)
+SetAllDrivers()
+UpdateStatusAsync(orderId, status, trackingNumber)
+CancelUserAsync(id, UserCancelableStatuses)
+ClaimDrivenOrder(orderId, userId, email)
Caller's own orders (id from the token)
Scoped
GoogleRecaptchaVerifier
dropped when no SecretKey, fails closed on errors
issues the token
«static»
JwtTokens
claims: sub, name, email, role, stamp
re-reads the account on every API request
+Create(user, settings, now) : PE256
-TokenExtensionAsync(context)
Order.PlacedInEnglish
«static»
AuthCookieProtocol
Idle Timeout = 30 min
MaxSessionAge = 8 h
-Build(user, signedAt)
-Read(tokenAsync context)
«interface»
EmailSender
-Send(async(to, subject, body, english)
token endpoint, admin list
Scoped
active= stamp= role= every request
keeps UserLifetimeEnglish current
active= stamp= role=
JwtSettings
+Issuer, Audience, (64chrs) + 15 min
Production without a key - app refuses to start
Development without a key - random key per run
+SigningKey - from Jwt.Key(32 bytes or more)
+FromConfiguration, environment)
names and prices read fine
signing key
«interface»
ICatalog
+attributes
+Enumerate
+FindJuiceLine(id)
+FindProduct(id)
+AvailableVariants(id)
+WithStatEntry(e)
«interface»
ICatalogAdmin
+CreateJuiceLine() / UpdateJuiceLine() / DeleteJuiceLine()
+CreateBaseProduct() / Update / Delete
+UpdateStockQuantity()
+UpdateImmediateStatus()
SqlCatalog
SqlOrderStore
prices shipping itself, inside the transaction
cost, weight, parcels
«static»
ShippingCalculator
30 kg per parcel, free from 2,000 kc
+Quote(carrier, grams, date, fromState)
SmtpEmailSender
AuthDir, used when EmailUsername is set
Taster in the language of the mail
«static»
SmtpLogin
CookieName = marcato.lang
only the values ea and en count
-ReadHttpContext() - English, Danish or not set
-WriteSetHttpContext()
«interface»
IUserAccountStore
+FindByEmail() / FindById()
+CreateUser() / UpdatePwHash()
+UpdateDisplayName() - also replaces the security stamp
+RotateSecurityStamp()
-RecordActivity() / DeleteUser()
-SetTempSecret() / SetTotpSecret()
-GetPreferredEnglish() - the language for emails
-ReplaceArchivedComments()
SqlUserAccountStore
TotpSecret encrypted with IDataProtector
LoggingEmailSender
prints the link to the console, via LogSafe
«static»
LogSafe
+Line(value)
-Block(value)

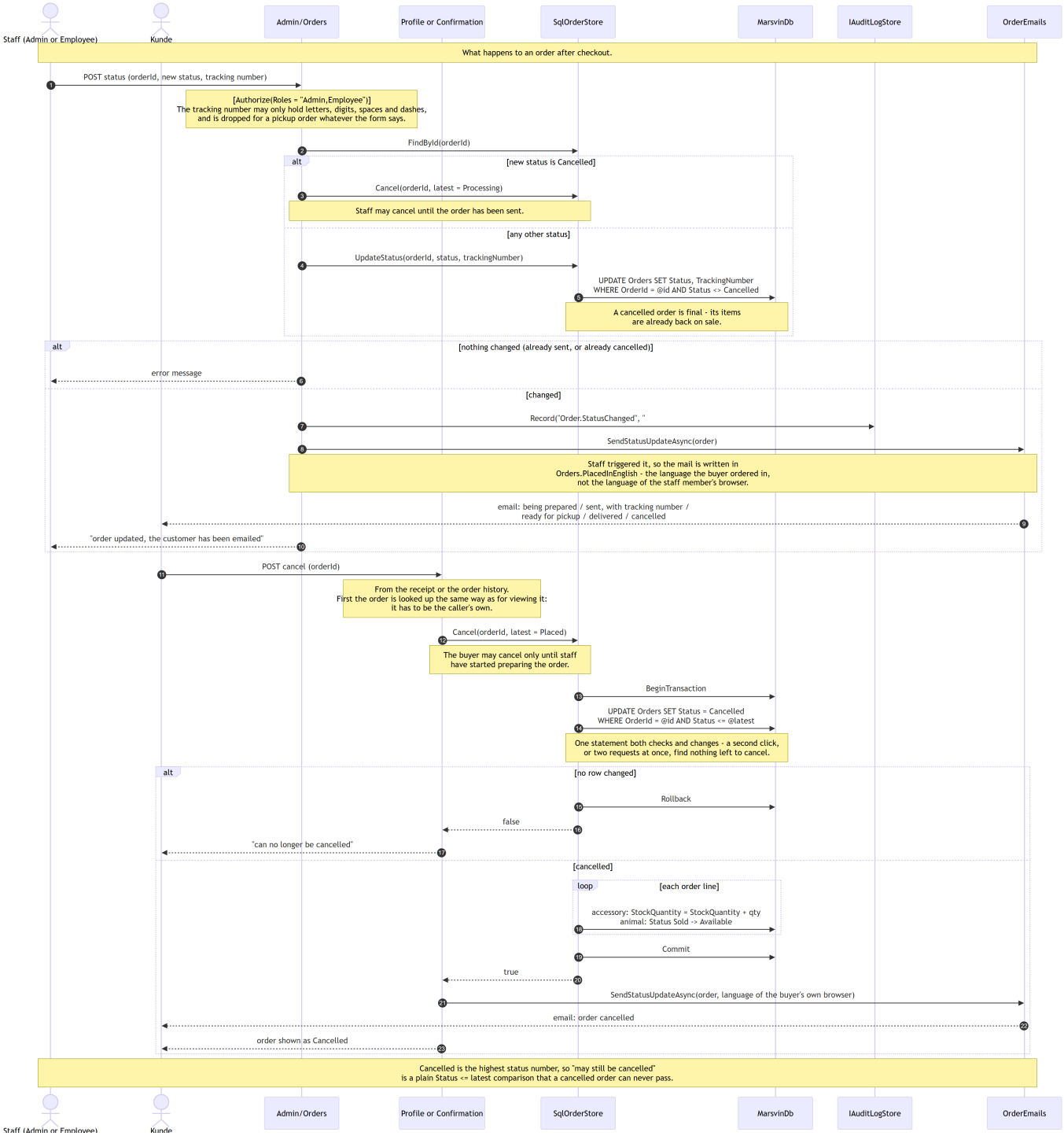

Trust boundary 1 – Kestrel, ASP.NET Core 9
Trust boundary 2 – SQL Server LocalDB
Untrusted zone – the Internet
External services
E1 Users
Customer, Admin
Traditional username + password, Security Stamp
E2 Products
Catalog + FoodProducts
E3 Cart/Basket
E4 Orders
E5 Orders / OrderItems
Promotions
E6 AuditLog
E7 Wishlists
SessionManager
E8 Stock
StockMovements
E9 Carriers/Manager
Email store.
Admin
Admin/Worker / Admin browser
Guest
Browser, no account
Authorization: Bearer token
forged, edited, expired or tampered token; user-controlled claims
donation form used to send/read to a stranger
stolen/unclear cookie
tampered productId, quantity, price, shipping cost
forced browsing to /claims, other people's orders
SQL injection, XSS, credential stuffing, scan, guessing
All requests
Untrusted input
Authorization: Bearer token
email + password over TLS
every signed-in request; Secure, HttpOnly, SameSite=Lax session cookie supplied by the account it's changed
auth cookie: HttpOnly, SameSite=Lax, 20-min idle, 8-h max
Captcha token
confirmation page
confirmation and email here
order confirmation
order status emails
item purchase records
donation thank-you, to the address typed in
password / email change and unlock notices
2 wrong tries, then delete
merge guest cart, claim guest order
Cookie: session id
Cookie: cart id
Cookie: checkout
Cookie: consent
Cookie: theme
Cookie: flash
Cookie: anti-forgery
Cookie: remember-me
Cookie: admin session
Cookie: admin remember-me
Cookie: admin anti-forgery
Cookie: admin flash
Cookie: admin theme
Cookie: admin sidebar
Cookie: admin table density
Cookie: admin column prefs
Cookie: admin saved filters
Cookie: admin last export
Cookie: admin dismissed banners
Cookie: admin keyboard shortcuts
Cookie: admin recent searches
Cookie: admin pinned items
Cookie: admin dashboard layout
Cookie: admin notification prefs
Cookie: admin session timeout
Cookie: admin audit filter
Cookie: admin export format
Cookie: admin bulk selection
Cookie: admin undo token
Cookie: admin last viewed
Cookie: admin favorites
Cookie: admin hidden columns
Cookie: admin sort order
Cookie: admin page size
Cookie: admin search history
Cookie: admin quick actions
Cookie: admin help dismissed
Cookie: admin tour progress
Cookie: admin keyboard layout
Cookie: admin locale
Cookie: admin timezone
Cookie: admin currency
Cookie: admin number format
Cookie: admin date format
Cookie: admin time format
Cookie: admin week start
Cookie: admin calendar view
Cookie: admin map zoom
Cookie: admin map center
Cookie: admin chart range
Cookie: admin chart type
Cookie: admin table columns
Cookie: admin table filters
Cookie: admin table sort
Cookie: admin table page
Cookie: admin table search
Cookie: admin table density

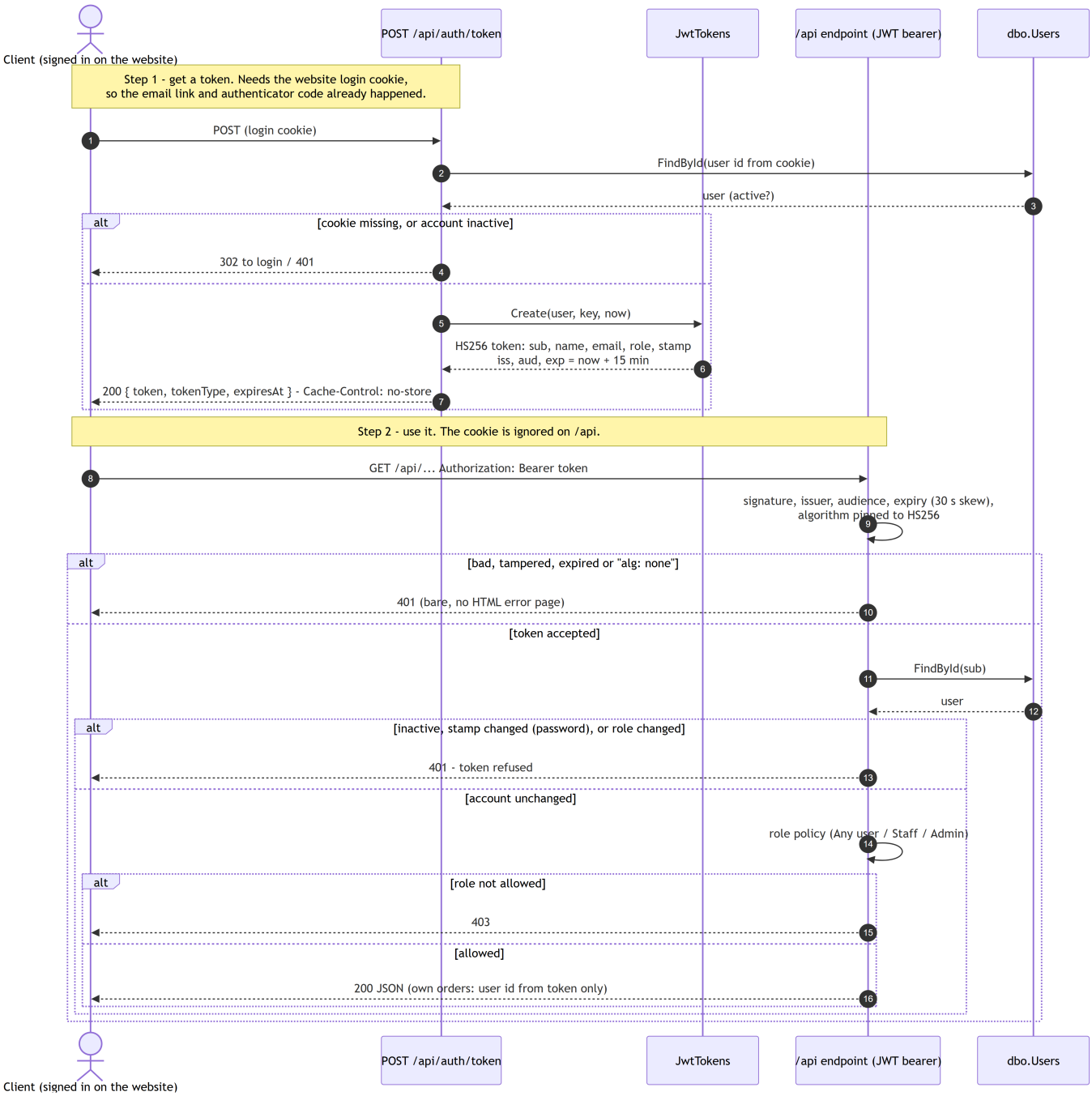

/ Index
chat bubble on every public page
404, expired form 400, 429, 403
Public - on the explicit allow-list in Program.cs (deny by default)
/Faq
/OmOs
/Kontakt
contact form, rate limited
/Stoet
donations (demo), rate limited, thank-you email if an address is given
/Chat
POST only - behind the Pip bubble, rate limited 20/min
/Error?code= and /ServerError
/Privatliv
/Marsvin
photo animals first
/Pasningsguide
/Maerker
brand filter
/Marsvin/Details/{id}
/PasningsguideHurtig
/Tilbehor
search, category / price / brand filters, sort, 24 per page
/BetalingOgLevering
/Foderliste
PDF downloads - QuestPDF, public
/PasningsguideHurtig/Pdf
/Foderliste/Pdf
add to cart, then ask: cart or keep shopping
add to cart
Public, but not for staff accounts - guest or Customer
/Cart
guest: session cart, Customer: database cart
/Cart/Payment
details, delivery + carrier, payment
guest or Customer
/Cart/Confirmation/{orderId}
own order only - status, cancel
guest may create an account instead
Anonymous - sign-in flow, rate limited
/Account/Login
/Account/Register
password ok, no 2FA
password ok, TOTP enrolled
/Account/ForgotPassword
/Account/CheckEmail
/Account/VerifyTotp?token=
emailed link
/Account/ResetPassword?token=
emailed link
/Account/ConfirmLogin?token=
/Account/Logout (POST)
/Account/AccessDenied
Customer
Role = staff -> dashboard
signs in, merges guest cart, claims the guest order
Role = staff -> dashboard
signs in, merges guest cart
log out everywhere
not signed in, idle 30 min, 8 h old, or password changed
[Authorize(Roles=Admin,Employee)] - admin shell: left sidebar on every page
/Admin - dashboard (Oversigt) sidebar groups: Dashboard / Operations / Shop / Administration
Signed in - any role
/Account/Profile details, password, TOTP, log out everywhere, staff: shifts and time off, Customer: orders, cancel, delete account
Employee
sidebar
/Admin/Stock
sidebar
/Admin/Orders status + tracking number
sidebar
/Admin/Messages
sidebar
/Admin/Donations
sidebar
/Admin/Schedule assign and decide: Admin only, inside the handlers
kept, by URL
/Admin/Shop - shop overview (kept, reachable by URL; the sidebar links pages directly)
sidebar: Admin only
sidebar: Admin only
sidebar: Admin only
sidebar: Admin only
sidebar: Admin only
sidebar: Admin only
kept, by URL
signed in, ask for a token
[Authorize(Roles=Admin)]
/Admin/Products + Edit
/Admin/Animals + Edit
/Admin/Promotions + Edit
/Admin/Users
/Admin/Users/Export/{id}
/Admin/AuditLog
/Admin/SecurityLog recorded attack attempts, severity-coded
/Admin/Administration - admin overview (kept, reachable by URL)
JSON API - JWT bearer, not pages (no HTML, bare 401 / 403 / 404)
POST /api/auth/token needs the website login cookie returns a 15 min token
Admin token
Authorization: Bearer
Staff token
/api/admin/users Admin only
/api/me, /api/orders any role - own data only
/api/admin/orders Admin and Employee

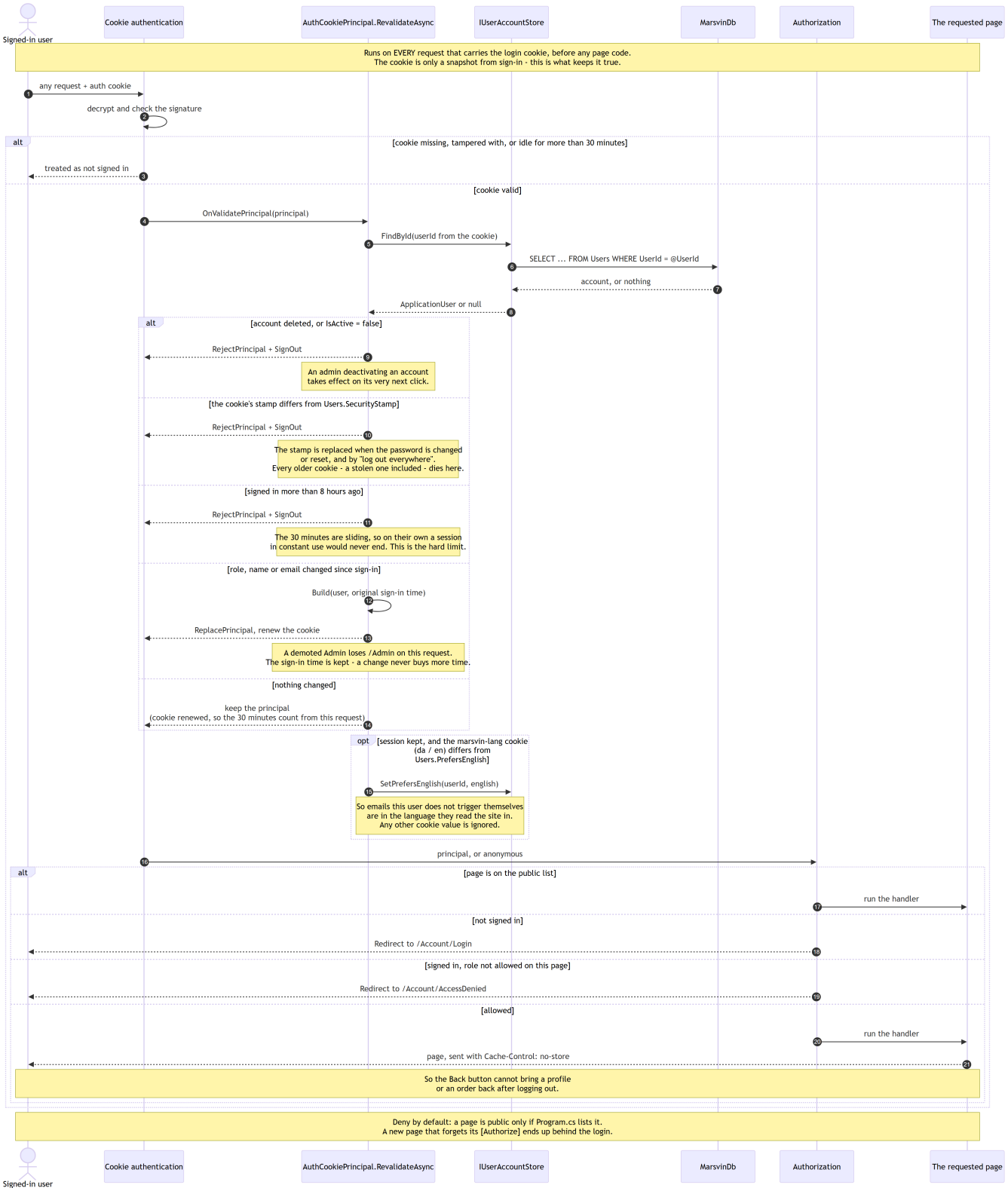

In the browser
EN / DA toggle (lang-toggle.js)
choice kept in localStorage
marsvin-lang cookie
'da' or 'en', path /, one year, SameSite=Lax
written on every page load
sent with every request
SiteLanguage.Read - the only place the cookie is read
cookie value?
exactly 'en'
exactly 'da'
anything else
English
Danish
not set
(missing, or any other value)
counts as Danish
Every signed-in request (AuthCookiePrincipal.RevalidateAsync):
copy the cookie to the account,
only when it is 'da' or 'en' AND differs.
Registration sets it for a new account
An email is about to be sent
Who caused the mail?
The recipient, in their own browser:
login link, new account, password reset, password or email changed, order confirmation, donation thank-you, cancelling their own order
Someone else, about an account:
shift added or removed, day-off request
to the admins, failed-login warning
Nobody: the daily inactivity job
Language of this request
PageModel.IsEnglish()
Users.PrefersEnglish
of the recipient
Checkout stores the request's language on the order
Staff, about an order:
status changed on /Admin/Orders
Orders.PlacedInEnglish
saved at checkout
IEmailSender.SendAsync(to, subject, body, english)
subject and body already written in that language;
the flag only picks the footer the sender adds
Mail in Danish or English, footer included
The cookie is never echoed anywhere - it is compared against two fixed values, so a tampered value cannot inject text into a mail or a page.
Product names in an order mail stay as the order recorded them (Danish).
Accounts and orders from before this existed count as Danish.

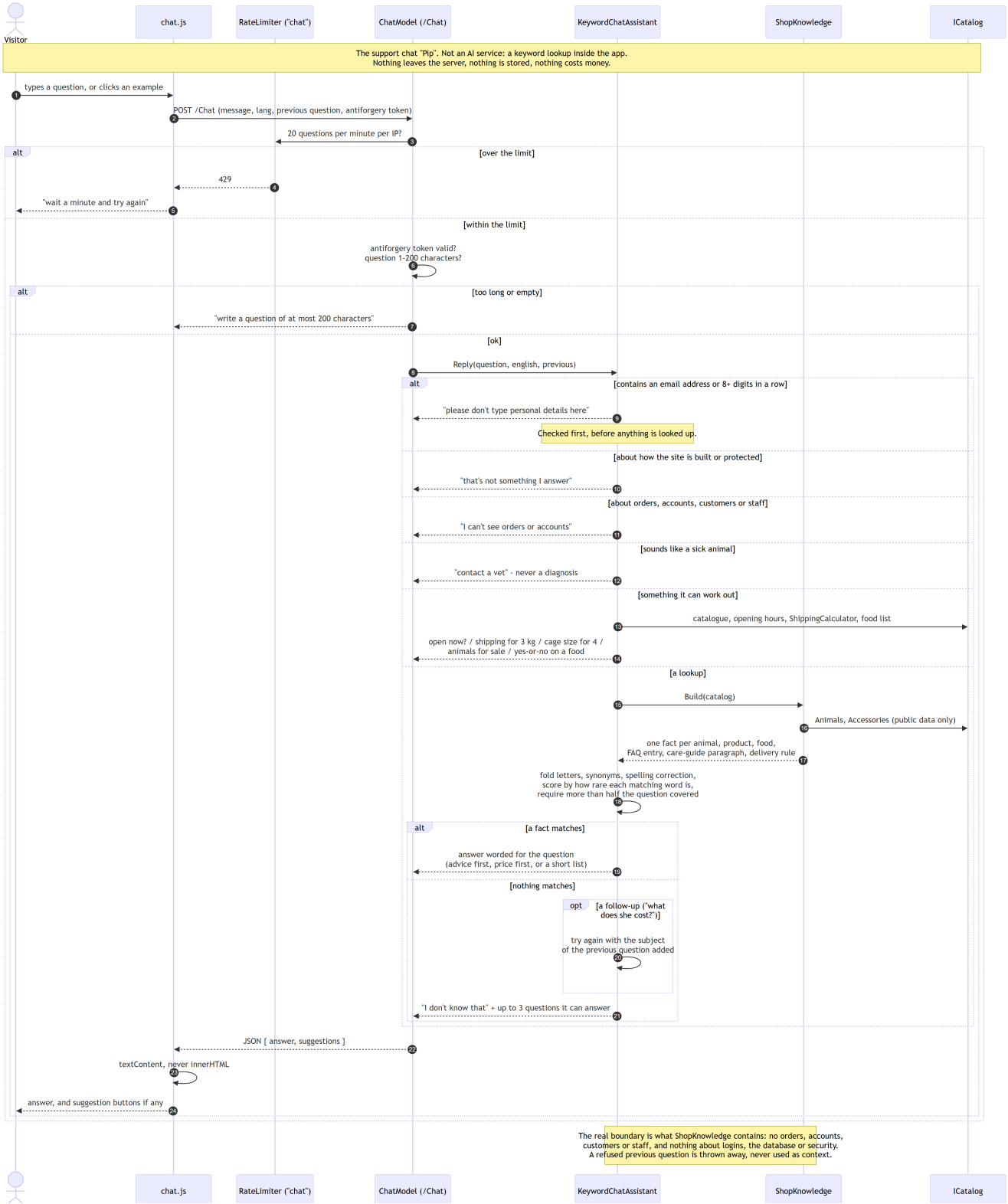

Giver (guest or signed in)
StoetModel
RateLimiter ("auth")
IRecaptchaVerifier
IInboxStore
MarsvinDb
IEmailSender
Staff
A public form. A money donation is a demo like the checkout:
it is recorded, never charged, and no card details are asked for.
POST /Stoet (kind, amount or item description,
name, email, greeting, captcha token)
50 requests per minute per IP?
alt
[over the limit]
429 Too Many Requests
[within the limit]
alt
[Money: amount missing or outside 10 - 10,000 kr.]
Page() with the field marked
[Products: description, name or email missing]
Page() with the fields marked
Only the fields of the chosen kind are required -
a money donation may be anonymous.
[valid]
VerifyAsync(captcha token)
alt
[captcha rejected]
"Bekraeft at du ikke er en robot"
[captcha ok]
AddDonation(donation)
INSERT Donations
Only the fields that belong to the chosen kind are kept,
whatever else the form posted.
opt
[an email address was given]
IsEnglish()? - the marsvin-lang cookie of this request
SendAsync(donor email, "Tak for din donation til Marsvin"
or "Thank you for your donation to Marsvin")
Fixed wording: the amount, or the shop's address and opening hours.
The donor's own free text (what they offer, their greeting) is NOT repeated,
and the name is kept to one line - the address is whatever was typed in,
so the form must not become a way to send a stranger your own wording.
alt
[sending failed]
Logged only. The donation is already saved,
so the giver still sees the thank-you and a retry
cannot become a second donation.
Redirect to /Stoet with a thank-you toast
GET /Admin/Donations (Admin or Employee)
SELECT the most recent donations
list - amount or items, name, email, greeting
An anonymous money donation sends no mail - there is nobody to write to.

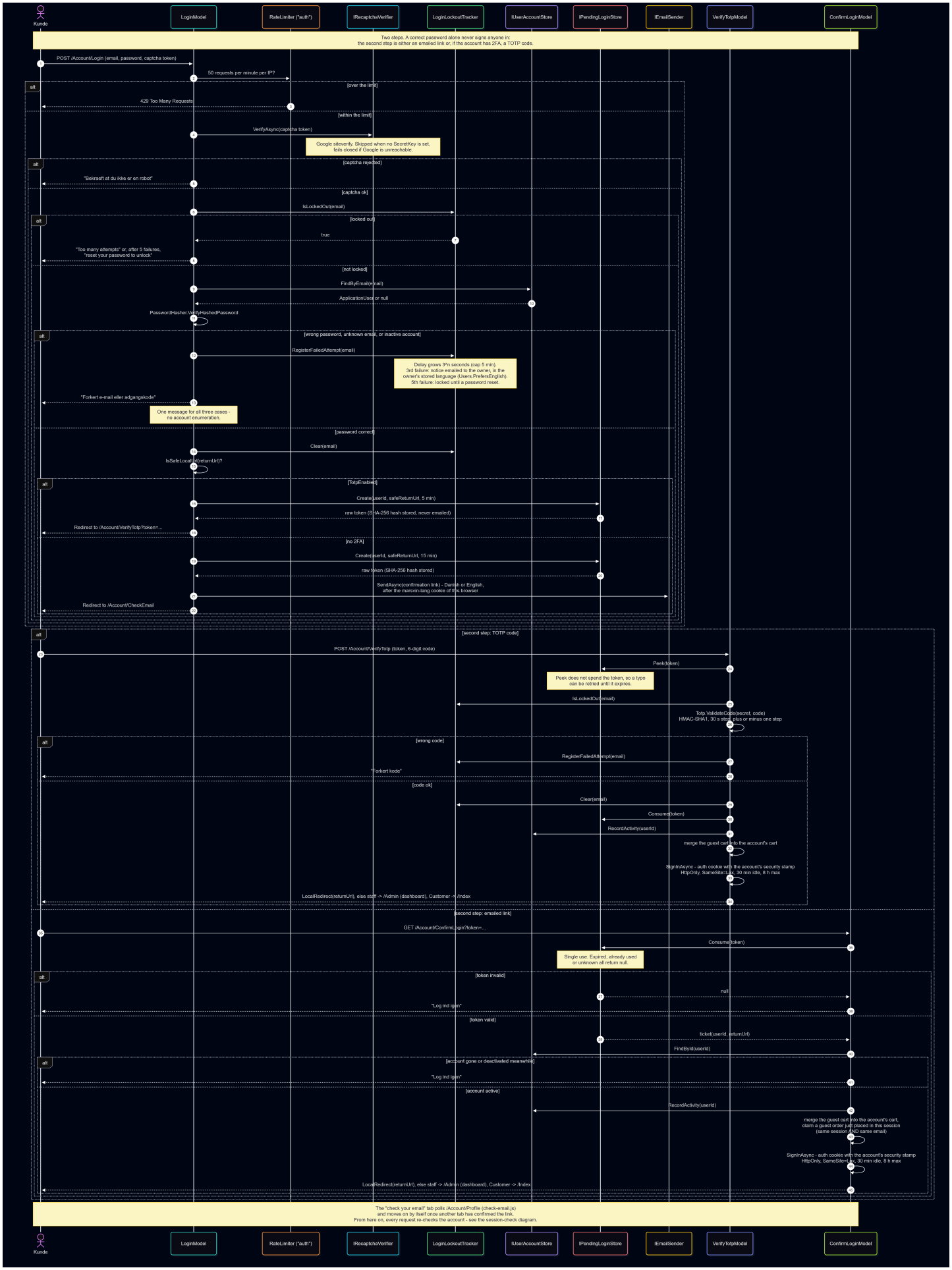

Kunde or Gaest
PaymentModel
ICartStore
SqlOrderStore
ShippingCalculator
MarsvinDb
Session
IEmailSender
ConfirmationModel
As built. No payment provider is contacted - the card or MobilePay
choice is stored on the order, and card details are only checked for shape.
No account is needed: ICartStore is the database cart for a Customer
and the session cart for a guest.
POST /Cart/Payment (name + email if guest, phone, buyer type,
company + CVR, age box, delivery, address, carrier,
paymentMethod, card fields)
1
Public page, but Employee and Admin
are turned away - staff accounts cannot buy.
GetLines(userId)
2
CartLine list (live prices and weights)
3
alt
[cart empty]
Redirect to /Cart
4
[something that applies is missing or malformed]
Only what applies is required: guest name + email,
phone and address if Shipping, age box if an animal,
company name + CVR check digit if Company,
card digits if Card (spaces and slash optional).
Page() with the fields marked
5
[valid]
Checkout(userId or null, delivery, address, carrier, paymentMethod,
guestName, guestEmail, guestLines, phone, ageConfirmed, company, cvr, placedInEnglish)
6
BeginTransaction
7
SELECT CartItems JOIN Products / Animals / StockProducts
8
lines with DB prices and weights
9
A guest has no CartItems rows, so the lines
PaymentModel already resolved are passed in
and re-validated against the database below.
alt
[cart empty]
Fail("Din kurv er tom")
10
[Shipping but all lines are animals, or no address]
Rollback
11
Fail(reason)
12
Re-checked here, never trusted from the form
loop
[each cart line]
SELECT ... WITH (UPDLOCK, HOLDLOCK)
13
Animal: Status = Available and at least 4 weeks old.
StockProduct: StockQuantity >= qty.
The lock stops two checkouts racing for the last unit.
alt
[any line invalid]
Rollback
14
Fail(reason)
15
[all lines valid]
opt
[Shipping]
Quote(carrier, weight of the shippable lines, today, their total)
16
cost, parcel count (max 20 kg each)
17
The form chooses a carrier - never a price.
Free when the shipped accessories reach 2,000 kr.
INSERT Orders (Status = Placed, TotalPrice = DB prices + shipping,
ShippingCost / WeightGrams / ParcelCount snapshots,
guest name + email or UserId, phone, age, company, PlacedInEnglish)
18
INSERT OrderItems (ProductName, UnitPrice, IsAnimal snapshots)
19
loop
[each cart line]
Animal to Sold, or StockQuantity = StockQuantity - qty
20
DELETE CartItems for this user
21
Commit
22
Ok(order)
23
Clear(userId)
24
opt
[guest]
SetInt32("GuestOrderId", orderId)
25
The guest's receipt pass: only this browser's
session ever holds this order id.
SendAsync("Ordrebekraeftelse" or "Order confirmation")
26
Written in the language the order was placed in:
the marsvin-lang cookie of this request, saved on the order.
Redirect to /Cart/Confirmation/{orderId}
27
GET /Cart/Confirmation/{orderId}
28
alt
[signed in]
FindForUser(orderId, userId)
29
Takes both ids, so changing orderId in the URL
to someone else's order just returns 404 (no IDOR).
[guest]
GetInt32("GuestOrderId") == orderId?
30
FindById(orderId), only on a match
31
receipt: status steps, delivery, expected delivery,
pickup note if an animal is in a shipped order
32
on Fail: Redirect to /Cart with the error message
33
One transaction covers validation, shipping price, insert,
stock change and cart clear - any failure rolls the whole thing back.

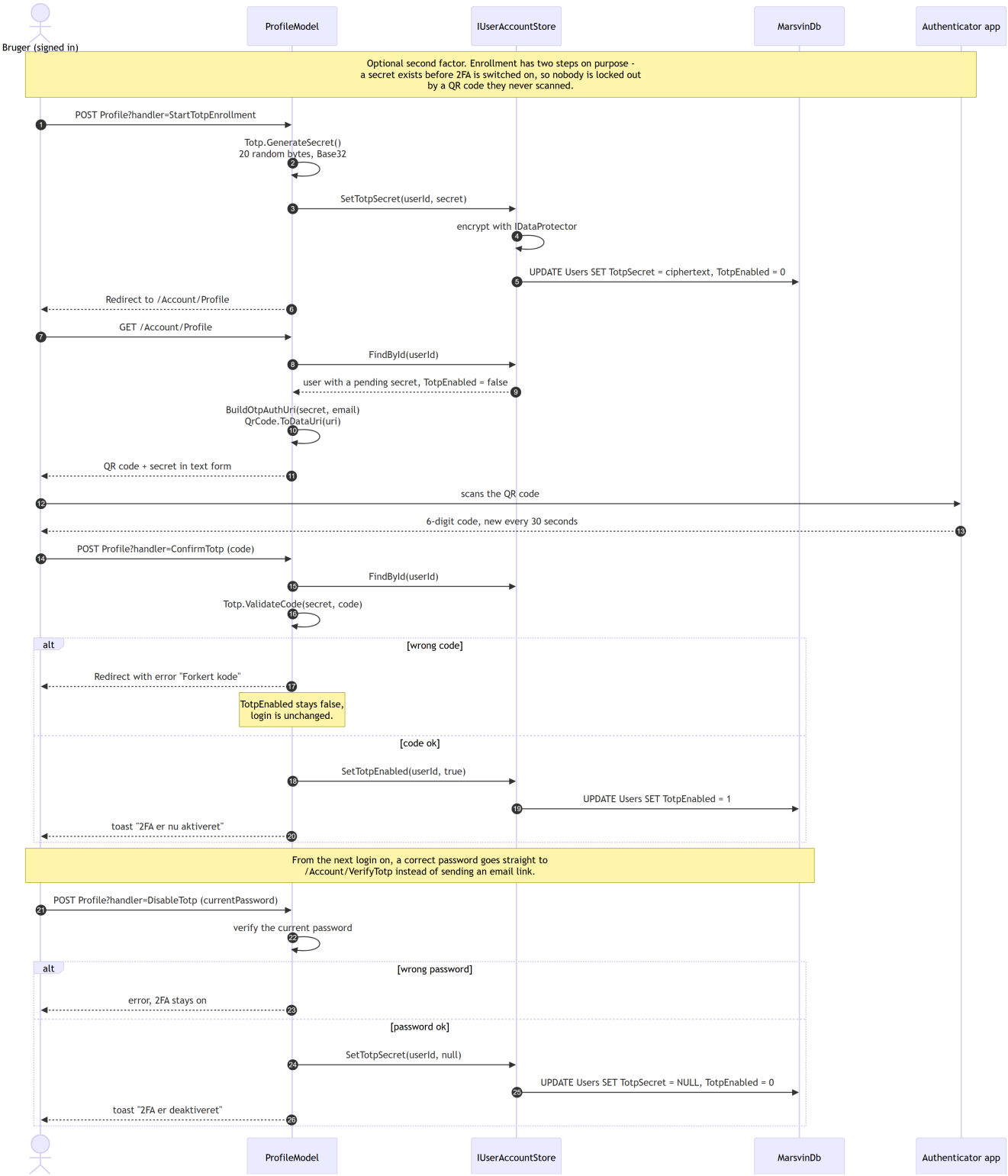

Staff (Admin or Employee)
Kunde
Admin/Orders
Profile or Confirmation
SqlOrderStore
MarsvinDb
IAuditLogStore
OrderEmails
What happens to an order after checkout.
POST status (orderId, new status, tracking number)
[Authorize(Roles = "Admin,Employee")]
The tracking number may only hold letters, digits, spaces and dashes, and is dropped for a pickup order whatever the form says.
FindById(orderId)
alt
[new status is Cancelled]
Cancel(orderId, latest = Processing)
Staff may cancel until the order has been sent.
[any other status]
UpdateStatus(orderId, status, trackingNumber)
UPDATE Orders SET Status, TrackingNumber
WHERE OrderId = @id AND Status <> Cancelled
A cancelled order is final - its items are already back on sale.
alt
[nothing changed (already sent, or already cancelled)]
error message
[changed]
Record("Order.StatusChanged", '')
SendStatusUpdateAsync(order)
Staff triggered it, so the mail is written in Orders.PlacedInEnglish - the language the buyer ordered in, not the language of the staff member's browser.
email: being prepared / sent, with tracking number / ready for pickup / delivered / cancelled
"order updated, the customer has been emailed"
POST cancel (orderId)
From the receipt or the order history.
First the order is looked up the same way as for viewing it: it has to be the caller's own.
Cancel(orderId, latest = Placed)
The buyer may cancel only until staff have started preparing the order.
BeginTransaction
UPDATE Orders SET Status = Cancelled
WHERE OrderId = @id AND Status <= @latest
One statement both checks and changes - a second click, or two requests at once, find nothing left to cancel.
alt
[no row changed]
Rollback
false
"can no longer be cancelled"
[cancelled]
loop
[each order line]
accessory: StockQuantity = StockQuantity + qty
animal: Status Sold -> Available
Commit
true
SendStatusUpdateAsync(order, language of the buyer's own browser)
email: order cancelled
order shown as Cancelled
Cancelled is the highest status number, so "may still be cancelled" is a plain Status <= latest comparison that a cancelled order can never pass.

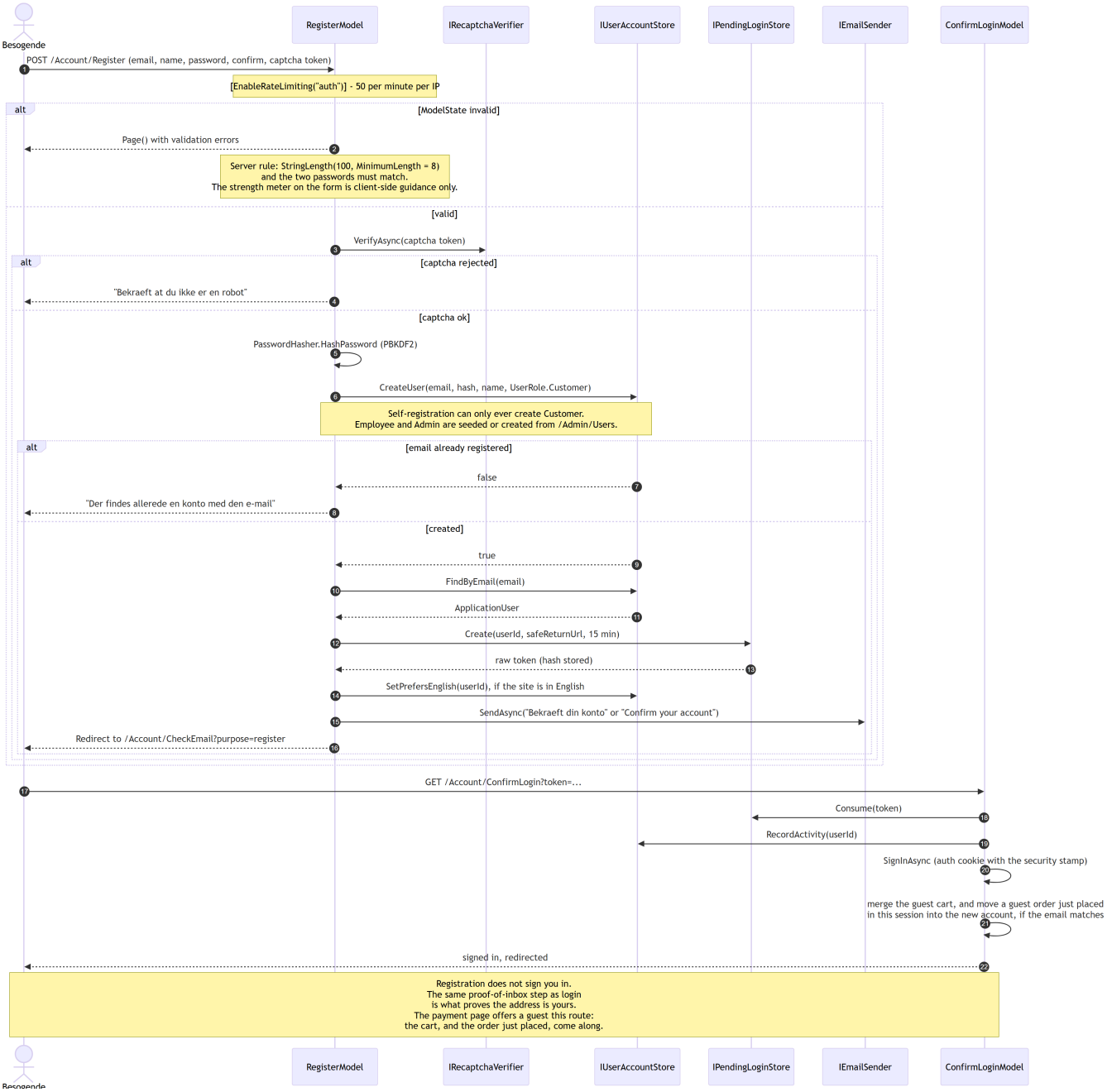

Client (signed in on the website)
POST /api/auth/token
JwtTokens
/api endpoint (JWT bearer)
dbo.Users
Step 1 - get a token. Needs the website login cookie,
so the email link and authenticator code already happened.
1
POST (login cookie)
2
FindById(user id from cookie)
3
user (active?)
alt
[cookie missing, or account inactive]
4
302 to login / 401
5
Create(user, key, now)
6
HS256 token: sub, name, email, role, stamp
iss, aud, exp = now + 15 min
7
200 { token, tokenType, expiresAt } - Cache-Control: no-store
Step 2 - use it. The cookie is ignored on /api.
8
GET /api/... Authorization: Bearer token
9
signature, issuer, audience, expiry (30 s skew),
algorithm pinned to HS256
alt
[bad, tampered, expired or "alg: none"]
10
401 (bare, no HTML error page)
[token accepted]
11
FindById(sub)
12
user
alt
[inactive, stamp changed (password), or role changed]
13
401 - token refused
[account unchanged]
14
role policy (Any user / Staff / Admin)
alt
[role not allowed]
15
403
[allowed]
16
200 JSON (own orders: user id from token only)
Client (signed in on the website)
POST /api/auth/token
JwtTokens
/api endpoint (JWT bearer)
dbo.Users

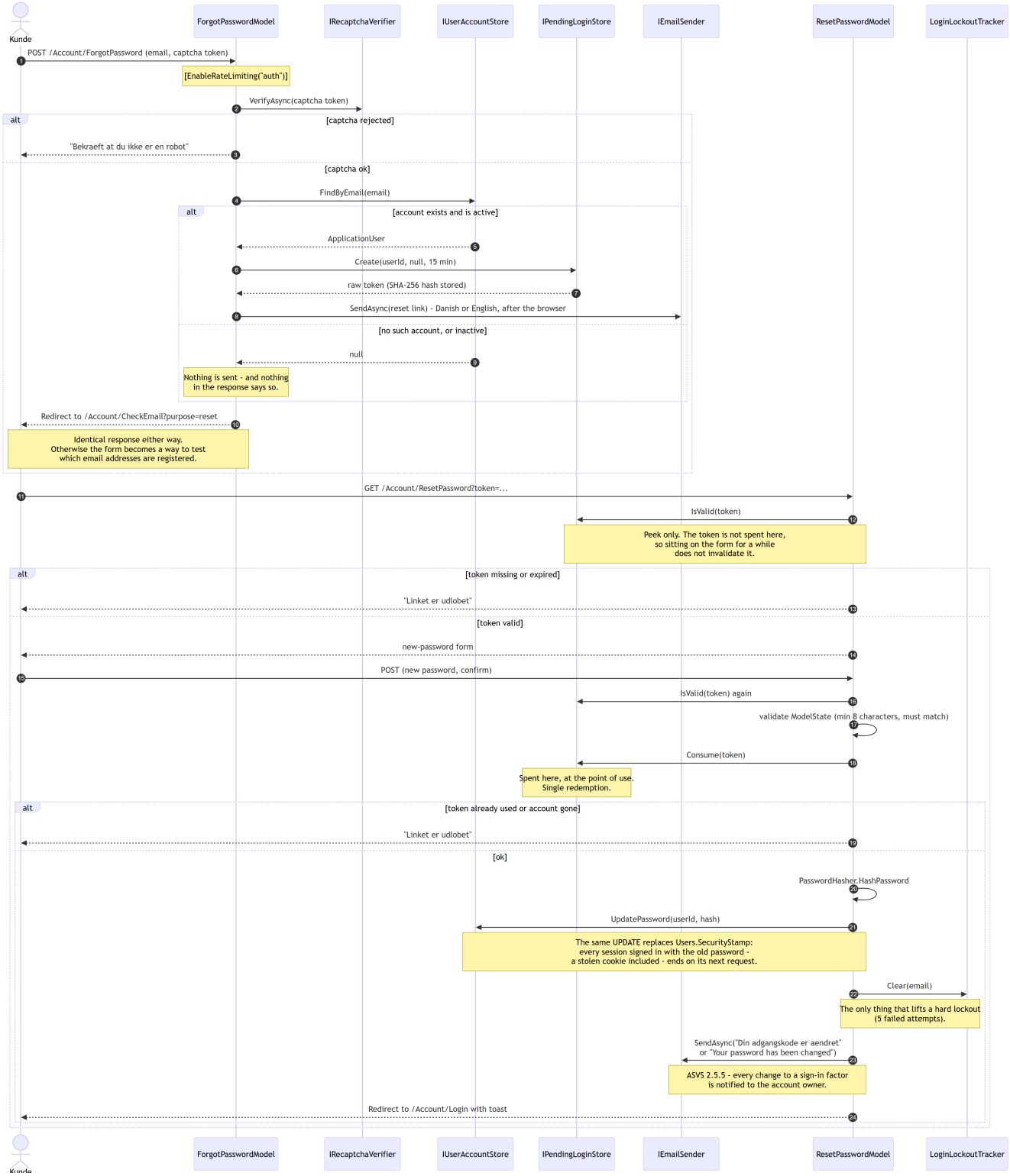

Signed-in user
Cookie authentication
AuthCookiePrincipal.RevalidateAsync
IUserAccountStore
MarsvinDb
Authorization
The requested page
Runs on EVERY request that carries the login cookie, before any page code.
The cookie is only a snapshot from sign-in - this is what keeps it true.
1 any request + auth cookie
2 decrypt and check the signature
alt
[cookie missing, tampered with, or idle for more than 30 minutes]
3 treated as not signed in
[cookie valid]
4 OnValidatePrincipal(principal)
5 FindById(userId from the cookie)
6 SELECT ... FROM Users WHERE UserId = @UserId
7 account, or nothing
8 ApplicationUser or null
alt
[account deleted, or IsActive = false]
9 RejectPrincipal + SignOut
An admin deactivating an account
takes effect on its very next click.
[the cookie's stamp differs from Users.SecurityStamp]
10 RejectPrincipal + SignOut
The stamp is replaced when the password is changed
or reset, and by "log out everywhere".
Every older cookie - a stolen one included - dies here.
[signed in more than 8 hours ago]
11 RejectPrincipal + SignOut
The 30 minutes are sliding, so on their own a session
in constant use would never end. This is the hard limit.
[role, name or email changed since sign-in]
12 Build(user, original sign-in time)
13 ReplacePrincipal, renew the cookie
A demoted Admin loses /Admin on this request.
The sign-in time is kept - a change never buys more time.
[nothing changed]
14 keep the principal
(cookie renewed, so the 30 minutes count from this request)
opt
[session kept, and the marsvin-lang cookie
(da / en) differs from
Users.PrefersEnglish]
15 SetPrefersEnglish(userId, english)
So emails this user does not trigger themselves
are in the language they read the site in.
Any other cookie value is ignored.
16 principal, or anonymous
alt
[page is on the public list]
17 run the handler
[not signed in]
18 Redirect to /Account/Login
[signed in, role not allowed on this page]
19 Redirect to /Account/AccessDenied
[allowed]
20 run the handler
21 page, sent with Cache-Control: no-store
So the Back button cannot bring a profile
or an order back after logging out.
Deny by default: a page is public only if Program.cs lists it.
A new page that forgets its [Authorize] ends up behind the login.
Signed-in user
Cookie authentication
AuthCookiePrincipal.RevalidateAsync
IUserAccountStore
MarsvinDb
Authorization
The requested page

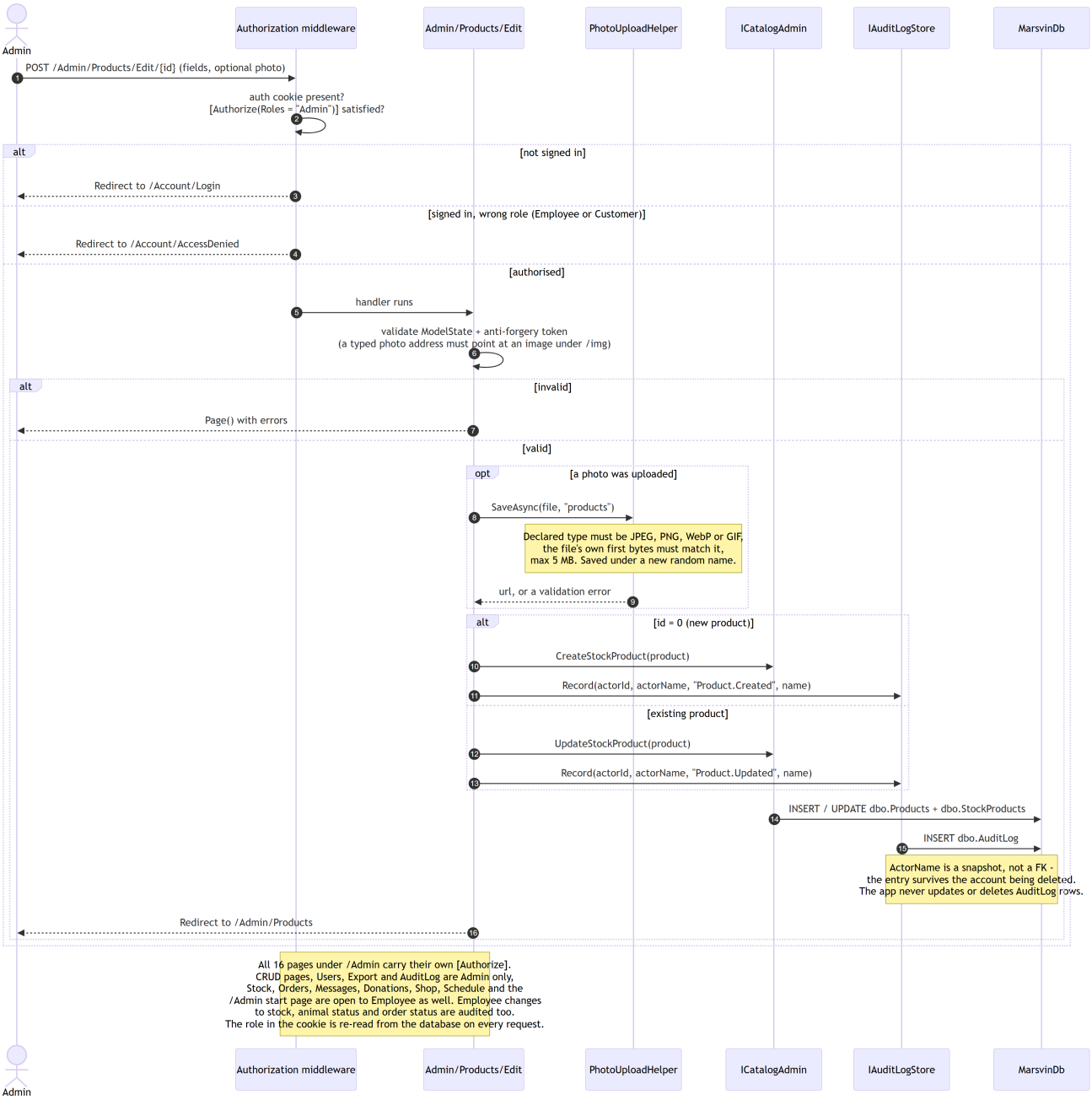

Visitor
chat.js
RateLimiter ("chat")
ChatModel (/Chat)
KeywordChatAssistant
ShopKnowledge
ICatalog
The support chat "Pip". Not an AI service: a keyword lookup inside the app.
Nothing leaves the server, nothing is stored, nothing costs money.
types a question, or clicks an example
POST /Chat (message, lang, previous question, antiforgery token)
20 questions per minute per IP?
alt
[over the limit]
429
"wait a minute and try again"
[within the limit]
antiforgery token valid?
question 1-200 characters?
alt
[too long or empty]
"write a question of at most 200 characters"
[ok]
Reply(question, english, previous)
alt
[contains an email address or 8+ digits in a row]
"please don't type personal details here"
Checked first, before anything is looked up.
[about how the site is built or protected]
"that's not something I answer"
[about orders, accounts, customers or staff]
"I can't see orders or accounts"
[sounds like a sick animal]
"contact a vet" - never a diagnosis
[something it can work out]
catalogue, opening hours, ShippingCalculator, food list
open now? / shipping for 3 kg / cage size for 4 /
animals for sale / yes-or-no on a food
[a lookup]
Build(catalog)
Animals, Accessories (public data only)
one fact per animal, product, food,
FAQ entry, care-guide paragraph, delivery rule
fold letters, synonyms, spelling correction,
score by how rare each matching word is,
require more than half the question covered
alt
[a fact matches]
answer worded for the question
(advice first, price first, or a short list)
[nothing matches]
opt
[a follow-up ("what does she cost?")]
try again with the subject
of the previous question added
"I don't know that" + up to 3 questions it can answer
JSON { answer, suggestions }
textContent, never innerHTML
answer, and suggestion buttons if any
The real boundary is what ShopKnowledge contains: no orders, accounts,
customers or staff, and nothing about logins, the database or security.
A refused previous question is thrown away, never used as context.

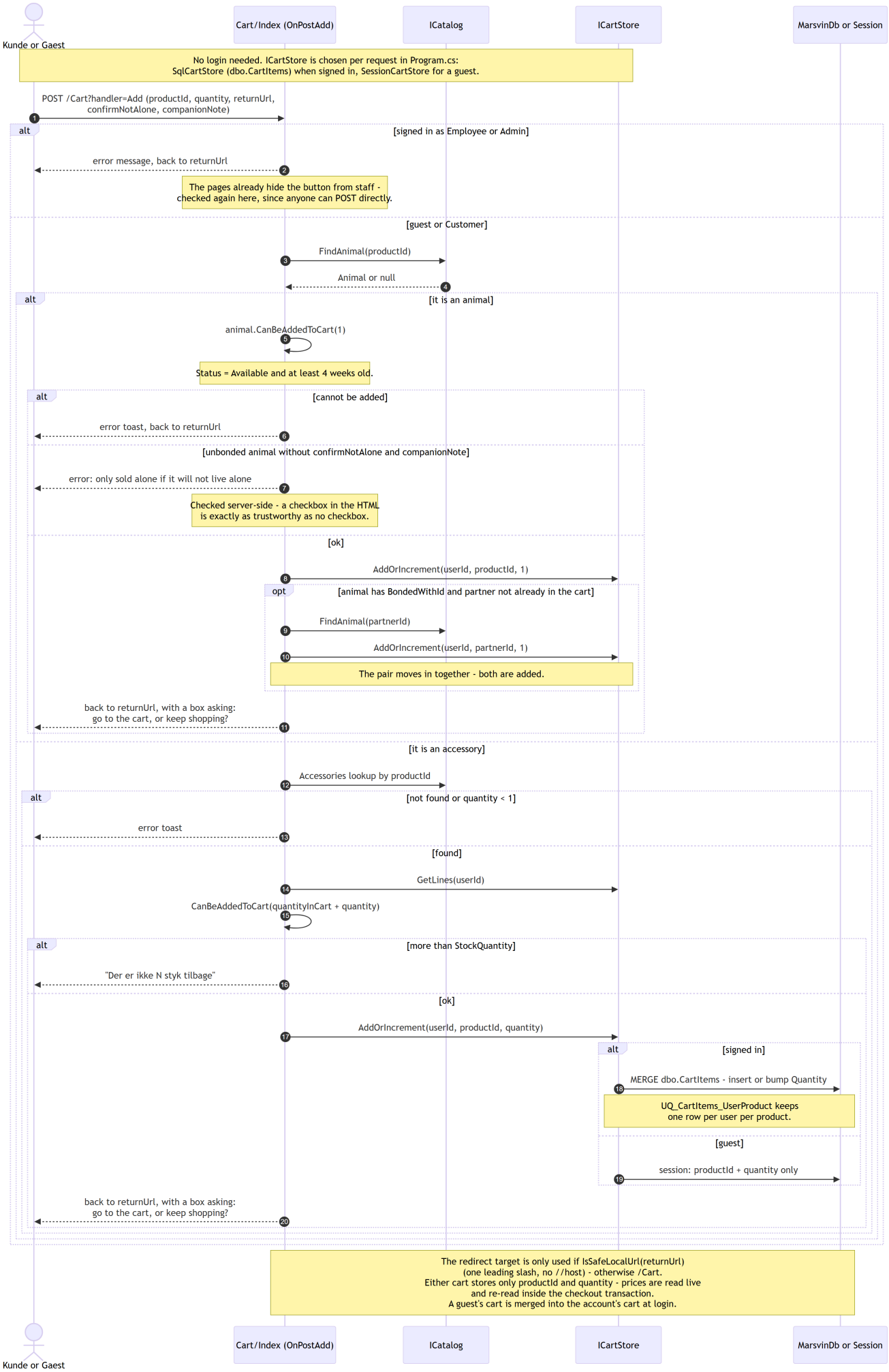

Kunde
LoginModel
RateLimiter ("auth")
IRecaptchaVerifier
LoginLockoutTracker
IUserAccountStore
IPendingLoginStore
IEmailSender
VerifyTotpModel
ConfirmLoginModel
Two steps. A correct password alone never signs anyone in:
the second step is either an emailed link or, if the account has 2FA, a TOTP code.
POST /Account/Login (email, password, captcha token)
50 requests per minute per IP?
alt
[over the limit]
429 Too Many Requests
[within the limit]
VerifyAsync(captcha token)
Google siteverify. Skipped when no SecretKey is set,
fails closed if Google is unreachable.
alt
[captcha rejected]
"Bekræft at du ikke er en robot"
[captcha ok]
IsLockedOut(email)
alt
[locked out]
true
"Too many attempts" or, after 5 failures,
"reset your password to unlock"
[not locked]
FindByEmail(email)
ApplicationUser or null
PasswordHasher.VerifyHashedPassword
alt
[wrong password, unknown email, or inactive account]
RegisterFailedAttempt(email)
Delay grows 3^n seconds (cap 5 min).
3rd failure: notice emailed to the owner, in the
owner's stored language (Users.PrefersEnglish).
5th failure: locked until a password reset.
"Forkert e-mail eller adgangskode"
One message for all three cases -
no account enumeration.
[password correct]
Clear(email)
IsSafeLocalUrl(returnUrl)?
alt
[TotpEnabled]
Create(userId, safeReturnUrl, 5 min)
raw token (SHA-256 hash stored, never emailed)
Redirect to /Account/VerifyTotp?token=...
[no 2FA]
Create(userId, safeReturnUrl, 15 min)
raw token (SHA-256 hash stored)
SendAsync(confirmation link) - Danish or English,
after the mørsvin-lang cookie of this browser
Redirect to /Account/CheckEmail
[second step: TOTP code]
alt
POST /Account/VerifyTotp (token, 6-digit code)
Peek(token)
Peek does not spend the token, so a typo
can be retried until it expires.
IsLockedOut(email)
Totp.ValidateCode(secret, code)
HMAC-SHA1, 30 s step, plus or minus one step
alt
[wrong code]
RegisterFailedAttempt(email)
"Forkert kode"
[code ok]
Clear(email)
Consume(token)
RecordActivity(userId)
merge the guest cart into the account's cart
SignInAsync - auth cookie with the account's security stamp
HttpOnly, SameSite=Lax, 30 min idle, 8 h max
LocalRedirect(returnUrl), else staff -> /Admin (dashboard), Customer -> /Index
[second step: emailed link]
GET /Account/ConfirmLogin?token=...
Consume(token)
Single use. Expired, already used
or unknown all return null.
alt
[token invalid]
null
"Log ind igen"
[token valid]
ticket(userId, returnUrl)
FindById(userId)
alt
[account gone or deactivated meanwhile]
"Log ind igen"
[account active]
RecordActivity(userId)
merge the guest cart into the account's cart,
claim a guest order just placed in this session
(same session AND same email)
SignInAsync - auth cookie with the account's security stamp
HttpOnly, SameSite=Lax, 30 min idle, 8 h max
LocalRedirect(returnUrl), else staff -> /Admin (dashboard), Customer -> /Index
The "check your email" tab polls /Account/Profile (check-email.js)
and moves on by itself once another tab has confirmed the link.
From here on, every request re-checks the account - see the session-check diagram.

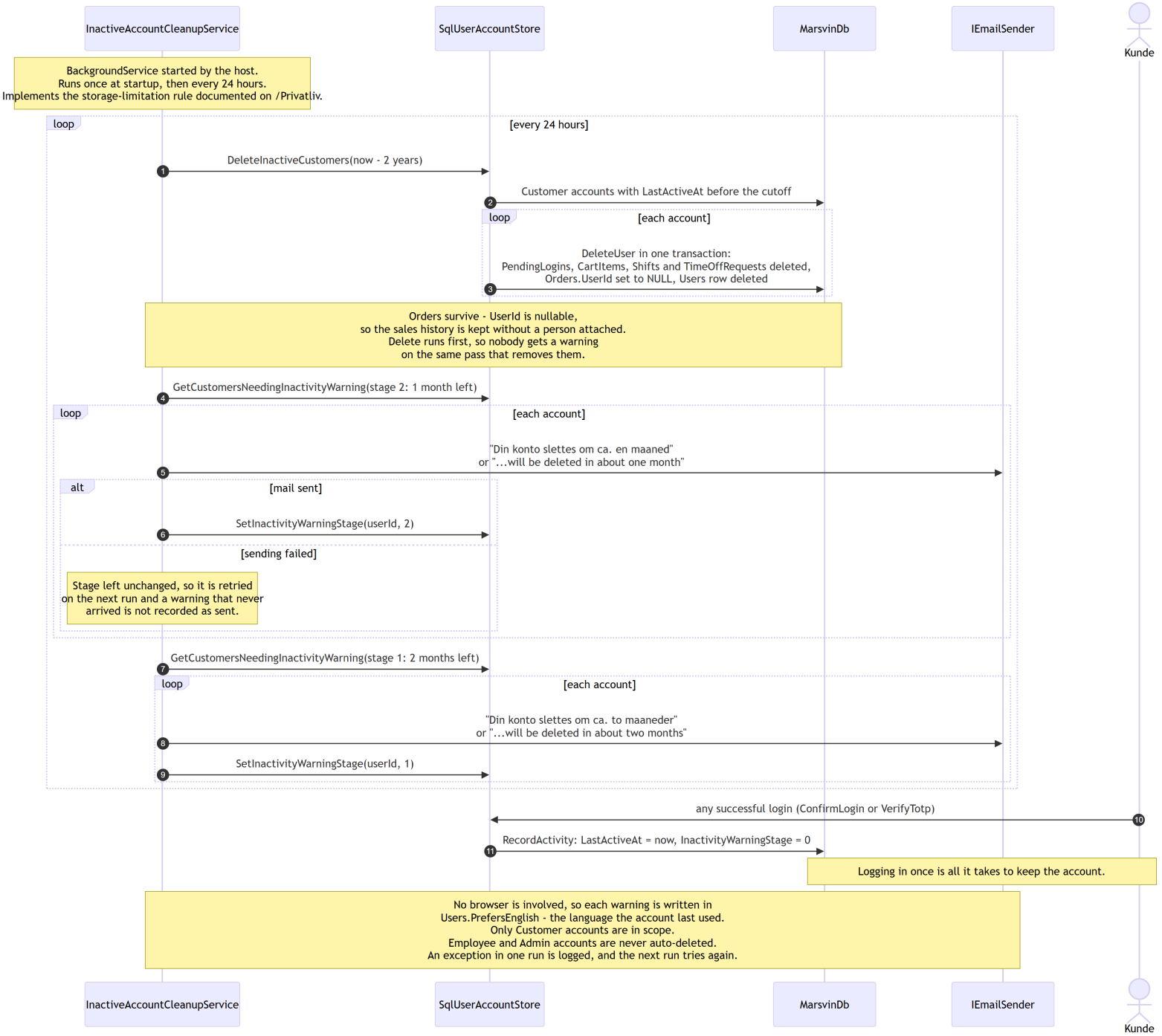

Bruger (signed in)
ProfileModel
IUserAccountStore
MarsvinDb
Authenticator app
Optional second factor. Enrollment has two steps on purpose - a secret exists before 2FA is switched on, so nobody is locked out by a QR code they never scanned.
1 POST Profile?handler=StartTotpEnrollment
2 Totp.GenerateSecret() 20 random bytes, Base32
3 SetTotpSecret(userId, secret)
4 encrypt with IDataProtector
5 UPDATE Users SET TotpSecret = ciphertext, TotpEnabled = 0
6 Redirect to /Account/Profile
7 GET /Account/Profile
8 FindById(userId)
9 user with a pending secret, TotpEnabled = false
10 BuildOtpAuthUri(secret, email) QrCode.ToDataUri(uri)
11 QR code + secret in text form
12 scans the QR code
13 6-digit code, new every 30 seconds
14 POST Profile?handler=ConfirmTotp (code)
15 FindById(userId)
16 Totp.ValidateCode(secret, code)
alt
[wrong code]
17 Redirect with error "Forkert kode"
TotpEnabled stays false, login is unchanged.
[code ok]
18 SetTotpEnabled(userId, true)
19 UPDATE Users SET TotpEnabled = 1
20 toast "2FA er nu aktiveret"
From the next login on, a correct password goes straight to /Account/VerifyTotp instead of sending an email link.
21 POST Profile?handler=DisableTotp (currentPassword)
22 verify the current password
alt
[wrong password]
23 error, 2FA stays on
[password ok]
24 SetTotpSecret(userId, null)
25 UPDATE Users SET TotpSecret = NULL, TotpEnabled = 0
26 toast "2FA er deaktiveret"
ProfileModel
IUserAccountStore
MarsvinDb
Authenticator app

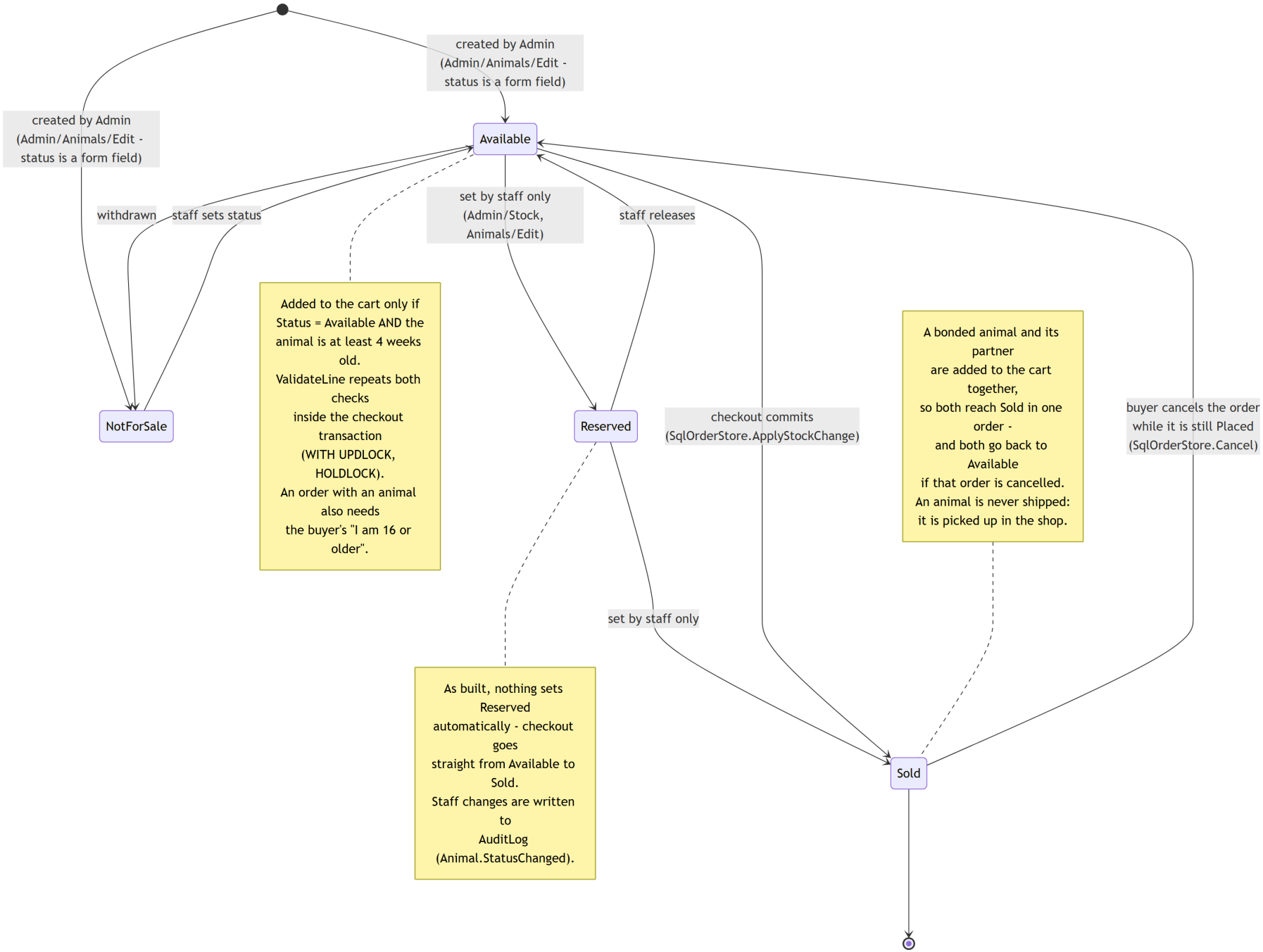

Besogende
RegisterModel
IRecaptchaVerifier
IUserAccountStore
IPendingLoginStore
IEmailSender
ConfirmLoginModel
POST /Account/Register (email, name, password, confirm, captcha token)
[EnableRateLimiting("auth")] - 50 per minute per IP
alt
[ModelState invalid]
Page() with validation errors
Server rule: StringLength(100, MinimumLength = 8)
and the two passwords must match.
The strength meter on the form is client-side guidance only.
[valid]
VerifyAsync(captcha token)
alt
[captcha rejected]
"Bekraeft at du ikke er en robot"
[captcha ok]
PasswordHasher.HashPassword (PBKDF2)
CreateUser(email, hash, name, UserRole.Customer)
Self-registration can only ever create Customer.
Employee and Admin are seeded or created from /Admin/Users.
alt
[email already registered]
false
"Der findes allerede en konto med den e-mail"
[created]
true
FindByEmail(email)
ApplicationUser
Create(userId, safeReturnUrl, 15 min)
raw token (hash stored)
SetPrefersEnglish(userId), if the site is in English
SendAsync("Bekraeft din konto" or "Confirm your account")
Redirect to /Account/CheckEmail?purpose=register
GET /Account/ConfirmLogin?token=...
Consume(token)
RecordActivity(userId)
SignInAsync (auth cookie with the security stamp)
merge the guest cart, and move a guest order just placed
in this session into the new account, if the email matches
signed in, redirected
Registration does not sign you in.
The same proof-of-inbox step as login
is what proves the address is yours.
The payment page offers a guest this route:
the cart, and the order just placed, come along.

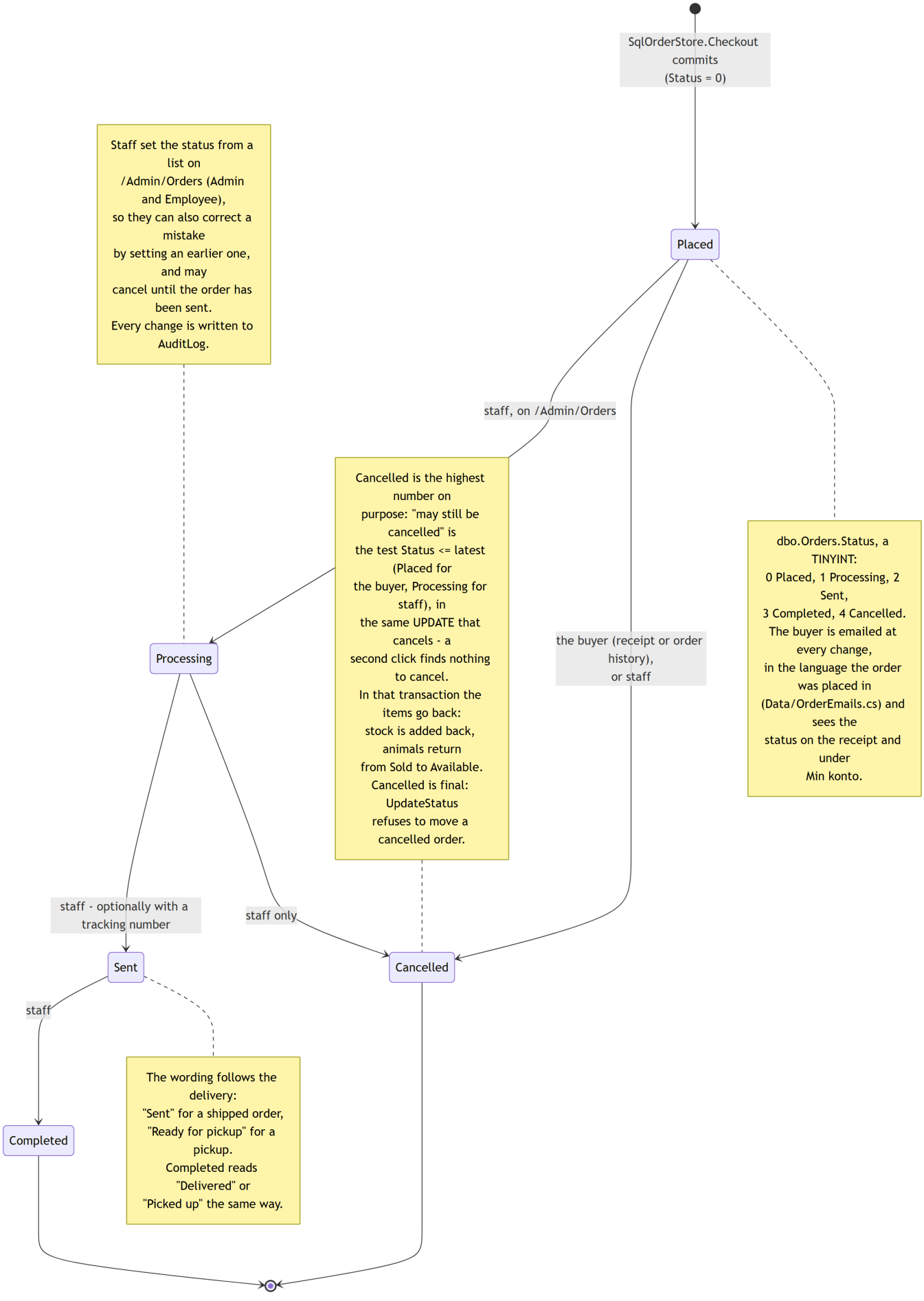

Kunde
ForgotPasswordModel
IRecaptchaVerifier
IUserAccountStore
IPendingLoginStore
IEmailSender
ResetPasswordModel
LoginLockoutTracker
POST /Account/ForgotPassword (email, captcha token)
[EnableRateLimiting("auth")]
VerifyAsync(captcha token)
alt
[captcha rejected]
"Bekraeft at du ikke er en robot"
[captcha ok]
FindByEmail(email)
alt
[account exists and is active]
ApplicationUser
Create(userId, null, 15 min)
raw token (SHA-256 hash stored)
SendAsync(reset link) - Danish or English, after the browser
[no such account, or inactive]
null
Nothing is sent - and nothing
in the response says so.
Redirect to /Account/CheckEmail?purpose=reset
Identical response either way.
Otherwise the form becomes a way to test
which email addresses are registered.
GET /Account/ResetPassword?token=...
IsValid(token)
Peek only. The token is not spent here,
so sitting on the form for a while
does not invalidate it.
alt
[token missing or expired]
"Linket er udlobet"
[token valid]
new-password form
POST (new password, confirm)
IsValid(token) again
validate ModelState (min 8 characters, must match)
Consume(token)
Spent here, at the point of use.
Single redemption.
alt
[token already used or account gone]
"Linket er udlobet"
[ok]
PasswordHasher.HashPassword
UpdatePassword(userId, hash)
The same UPDATE replaces Users.SecurityStamp:
every session signed in with the old password -
a stolen cookie included - ends on its next request.
Clear(email)
The only thing that lifts a hard lockout
(5 failed attempts).
SendAsync("Din adgangskode er aendret"
or "Your password has been changed")
ASVS 2.5.5 - every change to a sign-in factor
is notified to the account owner.
Redirect to /Account/Login with toast

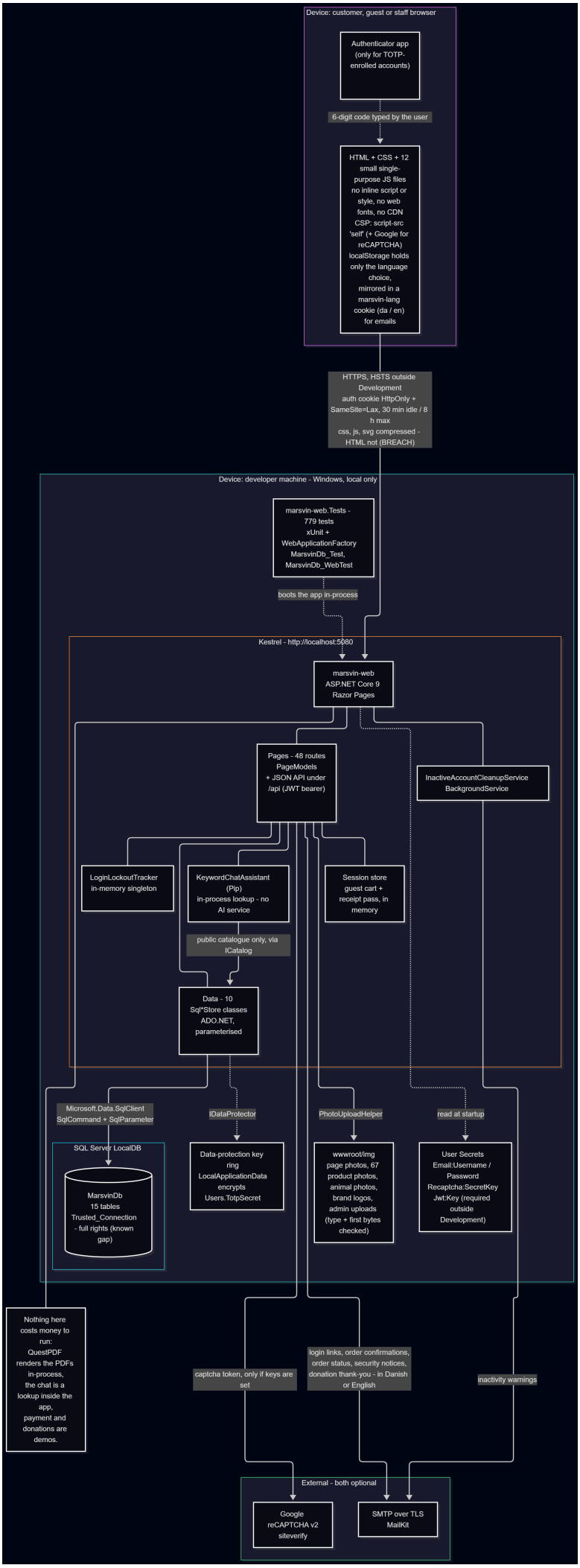

Admin
Authorization middleware
Admin/Products/Edit
PhotoUploadHelper
ICatalogAdmin
IAuditLogStore
MarsvinDb
POST /Admin/Products/Edit/{id} (fields, optional photo)
auth cookie present?
[Authorize(Roles = "Admin")] satisfied?
alt
[not signed in]
Redirect to /Account/Login
[signed in, wrong role (Employee or Customer)]
Redirect to /Account/AccessDenied
[authorised]
handler runs
validate ModelState + anti-forgery token
(a typed photo address must point at an image under /img)
alt
[invalid]
Page() with errors
[valid]
opt
[a photo was uploaded]
SaveAsync(file, "products")
Declared type must be JPEG, PNG, WebP or GIF,
the file's own first bytes must match it,
max 5 MB. Saved under a new random name.
url, or a validation error
alt
[id = 0 (new product)]
CreateStockProduct(product)
Record(actorId, actorName, "Product.Created", name)
[existing product]
UpdateStockProduct(product)
Record(actorId, actorName, "Product.Updated", name)
INSERT / UPDATE dbo.Products + dbo.StockProducts
INSERT dbo.AuditLog
ActorName is a snapshot, not a FK -
the entry survives the account being deleted.
The app never updates or deletes AuditLog rows.
Redirect to /Admin/Products
All 16 pages under /Admin carry their own [Authorize].
CRUD pages, Users, Export and AuditLog are Admin only,
Stock, Orders, Messages, Donations, Shop, Schedule and the
/Admin start page are open to Employee as well. Employee changes
to stock, animal status and order status are audited too.
The role in the cookie is re-read from the database on every request.

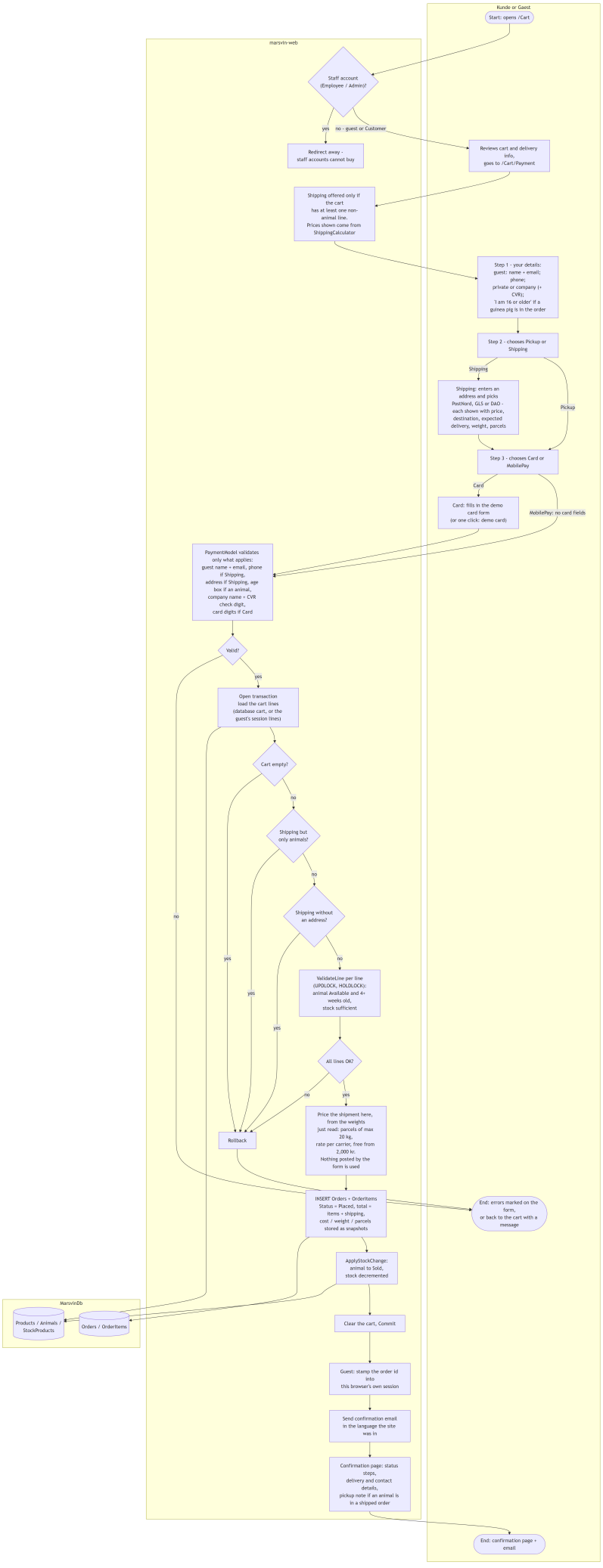

Kunde or Gaest
Cart/Index (OnPostAdd)
ICatalog
ICartStore
MarsvinDb or Session
No login needed. ICartStore is chosen per request in Program.cs:
SqlCartStore (dbo.CartItems) when signed in, SessionCartStore for a guest.
POST /Cart?handler=Add (productId, quantity, returnUrl, confirmNotAlone, companionNote)
1
alt
[signed in as Employee or Admin]
error message, back to returnUrl
2
The pages already hide the button from staff - checked again here, since anyone can POST directly.
[guest or Customer]
FindAnimal(productId)
3
Animal or null
4
alt
[it is an animal]
animal.CanBeAddedToCart(1)
5
Status = Available and at least 4 weeks old.
alt
[cannot be added]
error toast, back to returnUrl
6
[unbonded animal without confirmNotAlone and companionNote]
error: only sold alone if it will not live alone
7
Checked server-side - a checkbox in the HTML is exactly as trustworthy as no checkbox.
[ok]
AddOrIncrement(userId, productId, 1)
8
opt
[animal has BondedWithId and partner not already in the cart]
FindAnimal(partnerId)
9
AddOrIncrement(userId, partnerId, 1)
10
The pair moves in together - both are added.
back to returnUrl, with a box asking: go to the cart, or keep shopping?
11
[it is an accessory]
Accessories lookup by productId
12
alt
[not found or quantity < 1]
error toast
13
[found]
GetLines(userId)
14
CanBeAddedToCart(quantityInCart + quantity)
15
alt
[more than StockQuantity]
"Der er ikke N styk tilbage"
16
[ok]
AddOrIncrement(userId, productId, quantity)
17
alt
[signed in]
MERGE dbo.CartItems - insert or bump Quantity
18
UQ_CartItems_UserProduct keeps one row per user per product.
[guest]
session: productId + quantity only
19
back to returnUrl, with a box asking: go to the cart, or keep shopping?
20
The redirect target is only used if IsSafeLocalUrl(returnUrl) (one leading slash, no //host) - otherwise /Cart.
Either cart stores only productId and quantity - prices are read live and re-read inside the checkout transaction.
A guest's cart is merged into the account's cart at login.
Kunde or Gaest
Cart/Index (OnPostAdd)
ICatalog
ICartStore
MarsvinDb or Session

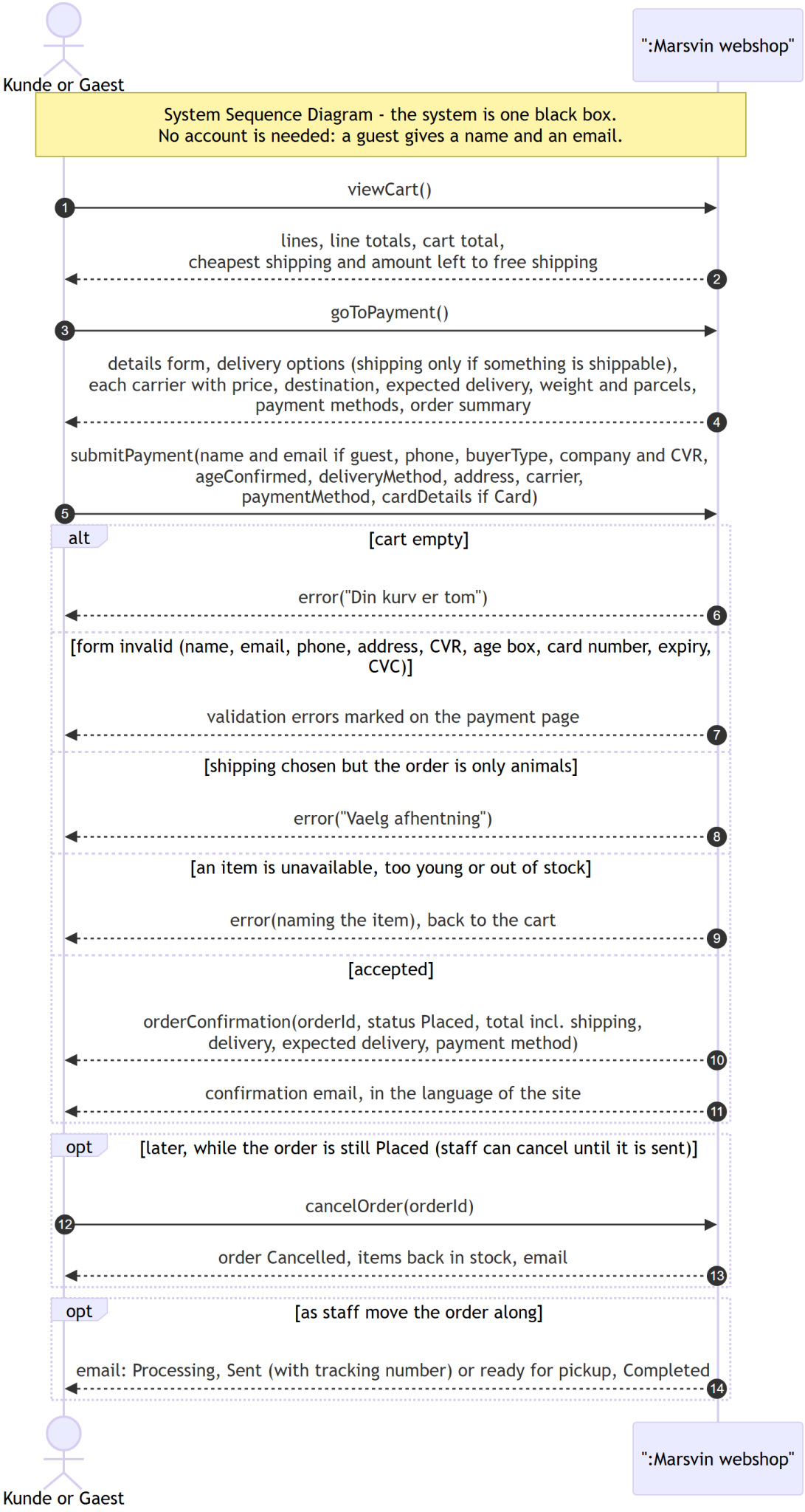

InactiveAccountCleanupService
SqlUserAccountStore
MarsvinDb
IEmailSender
Kunde
BackgroundService started by the host.
Runs once at startup, then every 24 hours.
Implements the storage-limitation rule documented on /Privatliv.
loop
[every 24 hours]
1 DeleteInactiveCustomers(now - 2 years)
2 Customer accounts with LastActiveAt before the cutoff
loop
[each account]
DeleteUser in one transaction:
PendingLogins, CartItems, Shifts and TimeOffRequests deleted,
Orders.UserId set to NULL, Users row deleted
3
Orders survive - UserId is nullable,
so the sales history is kept without a person attached.
Delete runs first, so nobody gets a warning
on the same pass that removes them.
4 GetCustomersNeedingInactivityWarning(stage 2: 1 month left)
loop
[each account]
5 "Din konto slettes om ca. en maaned"
or "...will be deleted in about one month"
alt
[mail sent]
6 SetInactivityWarningStage(userId, 2)
[sending failed]
Stage left unchanged, so it is retried
on the next run and a warning that never
arrived is not recorded as sent.
7 GetCustomersNeedingInactivityWarning(stage 1: 2 months left)
loop
[each account]
8 "Din konto slettes om ca. to maaneder"
or "...will be deleted in about two months"
9 SetInactivityWarningStage(userId, 1)
10 any successful login (ConfirmLogin or VerifyTotp)
11 RecordActivity: LastActiveAt = now, InactivityWarningStage = 0
Logging in once is all it takes to keep the account.
No browser is involved, so each warning is written in
Users.PrefersEnglish - the language the account last used.
Only Customer accounts are in scope.
Employee and Admin accounts are never auto-deleted.
An exception in one run is logged, and the next run tries again.
InactiveAccountCleanupService
SqlUserAccountStore
MarsvinDb
IEmailSender
Kunde

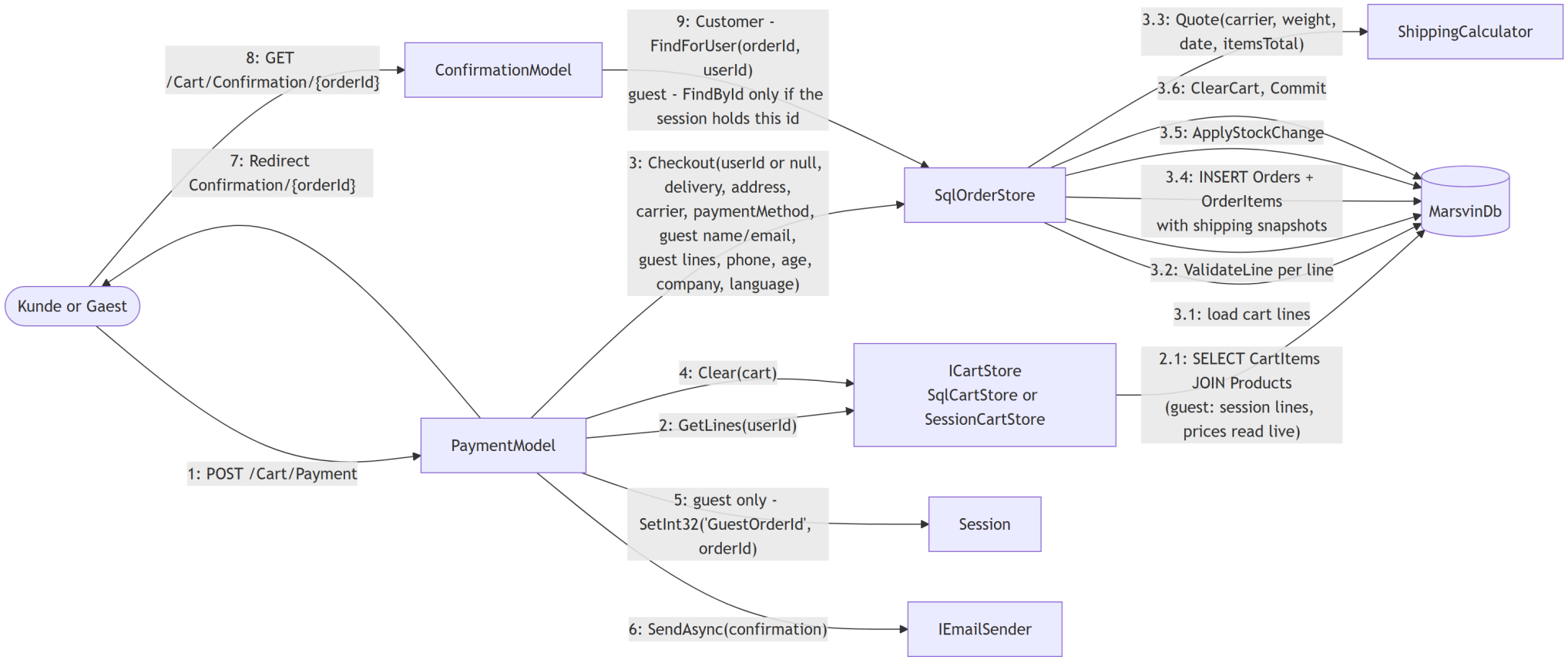

created by Admin
(Admin/Animals/Edit -
status is a form field)
created by Admin
(Admin/Animals/Edit -
status is a form field)
Available
withdrawn
staff sets status
set by staff only
(Admin/Stock,
Animals/Edit)
staff releases
Added to the cart only if
Status = Available AND the
animal is at least 4 weeks
old.
ValidateLine repeats both
checks
inside the checkout
transaction
(WITH UPDLOCK,
HOLDLOCK).
An order with an animal
also needs
the buyer's "I am 16 or
older".
NotForSale
Reserved
checkout commits
(SqlOrderStore.ApplyStockChange)
A bonded animal and its
partner
are added to the cart
together,
so both reach Sold in one
order -
and both go back to
Available
if that order is cancelled.
An animal is never shipped:
it is picked up in the shop.
buyer cancels the order
while it is still Placed
(SqlOrderStore.Cancel)
set by staff only
As built, nothing sets
Reserved
automatically - checkout
goes
straight from Available to
Sold.
Staff changes are written
to
AuditLog
(Animal.StatusChanged).
Sold


SqlOrderStore.Checkout commits (Status = 0)
Placed
Staff set the status from a list on /Admin/Orders (Admin and Employee), so they can also correct a mistake by setting an earlier one, and may cancel until the order has been sent. Every change is written to AuditLog.
staff, on /Admin/Orders
Cancelled is the highest number on purpose: "may still be cancelled" is the test Status <= latest (Placed for the buyer, Processing for staff), in the same UPDATE that cancels - a second click finds nothing to cancel. In that transaction the items go back: stock is added back, animals return from Sold to Available. Cancelled is final: UpdateStatus refuses to move a cancelled order.
dbo.Orders.Status, a TINYINT: 0 Placed, 1 Processing, 2 Sent, 3 Completed, 4 Cancelled. The buyer is emailed at every change, in the language the order was placed in (Data/OrderEmails.cs) and sees the status on the receipt and under Min konto.
Processing
the buyer (receipt or order history), or staff
staff - optionally with a tracking number
staff only
Sent
Cancelled
staff
Completed
The wording follows the delivery: "Sent" for a shipped order, "Ready for pickup" for a pickup. Completed reads "Delivered" or "Picked up" the same way.


Device: customer, guest or staff browser
Authenticator app (only for TOTP-enrolled accounts)
6-digit code typed by the user
HTML + CSS + 12 small single-purpose JS files no inline script or style, no web fonts, no CDN CSP: script-src 'self' (+ Google for reCAPTCHA) localStorage holds only the language choice, mirrored in a marsvin-lang cookie (da / en) for emails
HTTPS, HSTS outside Development
auth cookie HttpOnly + SameSite=Lax, 30 min idle / 8 h max
css, js, svg compressed - HTML not (BREACH)
Device: developer machine - Windows, local only
marsvin-web.Tests - 779 tests xUnit + WebApplicationFactory MarsvinDb_Test, MarsvinDb_WebTest
boots the app in-process
Kestrel - http://localhost:5080
marsvin-web ASP.NET Core 9 Razor Pages
Pages - 48 routes PageModels + JSON API under /api (JWT bearer)
InactiveAccountCleanupService BackgroundService
LoginLockoutTracker in-memory singleton
KeywordChatAssistant (Pip) in-process lookup - no AI service
Session store guest cart + receipt pass, in memory
public catalogue only, via ICatalog
Data - 10 Sql*Store classes ADO.NET, parameterised
Microsoft.Data.SqlClient SqlCommand + SqlParameter
IDataProtector
PhotoUploadHelper
read at startup
SQL Server LocalDB
MarsvinDb 15 tables Trusted_Connection - full rights (known gap)
Data-protection key ring LocalApplicationData encrypts Users.TotpSecret
wwwroot/img page photos, 67 product photos, animal photos, brand logos, admin uploads (type + first bytes checked)
User Secrets Email:Username / Password Recaptcha:SecretKey Jwt:Key (required outside Development)
Nothing here costs money to run: QuestPDF renders the PDFs in-process, the chat is a lookup inside the app, payment and donations are demos.
captcha token, only if keys are set
login links, order confirmations, order status, security notices, donation thank-you - in Danish or English
inactivity warnings
External - both optional
Google reCAPTCHA v2 siteverify
SMTP over TLS MailKit


Kunde or Gaest
Start: opens /Cart
marsvin-web
Staff account
(Employee / Admin)?
yes
no - guest or Customer
Redirect away -
staff accounts cannot buy
Reviews cart and delivery
info,
goes to /Cart/Payment
Shipping offered only if
the cart
has at least one non-
animal line.
Prices shown come from
ShippingCalculator
Step 1 - your details:
guest: name + email;
phone;
private or company (+
CVR);
'I am 16 or older' if a
guinea pig is in the order
Step 2 - chooses Pickup or
Shipping
Shipping
Pickup
Shipping: enters an
address and picks
PostNord, GLS or DAO -
each shown with price,
destination, expected
delivery, weight, parcels
Step 3 - chooses Card or
MobilePay
Card
Card: fills in the demo
card form
(or one click: demo card)
MobilePay: no card fields
PaymentModel validates
only what applies:
guest name + email, phone
if Shipping,
address if Shipping, age
box if an animal,
company name + CVR
check digit,
card digits if Card
Valid?
yes
no
Open transaction
load the cart lines
(database cart, or the
guest's session lines)
Cart empty?
no
yes
Shipping but
only animals?
no
yes
Shipping without
an address?
no
yes
ValidateLine per line
(UPDLOCK, HOLDLOCK):
animal Available and 4+
weeks old,
stock sufficient
yes
All lines OK?
no
yes
Rollback
Price the shipment here,
from the weights
Just read: parcels of max
20 kg,
rate per carrier, free from
2,000 kr.
Nothing posted by the
form is used
INSERT Orders + OrderItems
Status = Placed, total =
items + shipping,
cost / weight / parcels
stored as snapshots
End: errors marked on the
form,
or back to the cart with a
message
ApplyStockChange:
animal to Sold,
stock decremented
MarsvinDb
Products / Animals /
StockProducts
Orders / OrderItems
Clear the cart, Commit
Guest: stamp the order id
into
this browser's own session
Send confirmation email
in the language the site
was in
Confirmation page: status
steps,
delivery and contact
details,
pickup note if an animal is
in a shipped order
End: confirmation page +
email


Kunde or Gaest
":Marsvin webshop"
System Sequence Diagram - the system is one black box.
No account is needed: a guest gives a name and an email.
viewCart()
1
lines, line totals, cart total,
cheapest shipping and amount left to free shipping
2
goToPayment()
3
details form, delivery options (shipping only if something is shippable),
each carrier with price, destination, expected delivery, weight and parcels,
payment methods, order summary
4
submitPayment(name and email if guest, phone, buyerType, company and CVR,
ageConfirmed, deliveryMethod, address, carrier,
paymentMethod, cardDetails if Card)
5
alt
[cart empty]
error("Din kurv er tom")
6
[form invalid (name, email, phone, address, CVR, age box, card number, expiry, CVC)]
validation errors marked on the payment page
7
[shipping chosen but the order is only animals]
error("Vaelg afhentning")
8
[an item is unavailable, too young or out of stock]
error(naming the item), back to the cart
9
[accepted]
orderConfirmation(orderId, status Placed, total incl. shipping,
delivery, expected delivery, payment method)
10
confirmation email, in the language of the site
11
opt
[later, while the order is still Placed (staff can cancel until it is sent)]
cancelOrder(orderId)
12
order Cancelled, items back in stock, email
13
opt
[as staff move the order along]
email: Processing, Sent (with tracking number) or ready for pickup, Completed
14
Kunde or Gaest
":Marsvin webshop"


Kunde or Gaest
1: POST /Cart/Payment
PaymentModel
2: GetLines(userId)
4: Clear(cart)
ICartStore
SqlCartStore or
SessionCartStore
2.1: SELECT CartItems
JOIN Products
(guest: session lines,
prices read live)
3: Checkout(userId or null,
delivery, address,
carrier, paymentMethod,
guest name/email,
guest lines, phone, age,
company, language)
SqlOrderStore
3.1: load cart lines
3.2: ValidateLine per line
3.3: Quote(carrier, weight,
date, itemsTotal)
ShippingCalculator
3.4: INSERT Orders +
OrderItems
with shipping snapshots
3.5: ApplyStockChange
3.6: ClearCart, Commit
MarsvinDb
5: guest only -
SetInt32('GuestOrderId',
orderId)
Session
6: SendAsync(confirmation)
IEmailSender
7: Redirect
Confirmation/{orderId}
8: GET
/Cart/Confirmation/{orderId}
ConfirmationModel
9: Customer -
FindForUser(orderId,
userId)
guest - FindById only if the
session holds this id